Conception et déploiement d’une architecture réseau sécurisée multi-zones (WAN / LAN / DMZ)

Date : 21 Janvier 2026
Entreprise : NOVACYBER
Auteur : Touil Sofiane

Sommaire

1 Introduction et Contexte du Projet
2 Analyse des Besoins et Objectifs
3 Architecture Réseau et Plan d'Adressage
- 3.1 Topologie Logique
- 3.2 Plan d'Adressage IP

4 Installation et Configuration du Socle Réseau
- 4.1 Déploiement de pfSense
- 4.2 Configuration des Interfaces

5 Sécurisation et Filtrage (Pare-feu)
6 Services Avancés : Proxy et Authentification
7 Accès Distant Sécurisé (VPN)
8 Sécurité Offensive et Défensive (PoC)
9 Conclusion

---

1. Introduction et Contexte du Projet

L'entreprise **Novacyber** a récemment fait face à une croissance rapide de ses activités, entraînant une complexification de son infrastructure informatique. Jusqu'à présent, le réseau de l'entreprise était "plat", signifiant que l'ensemble des postes de travail, serveurs et équipements réseau cohabitaient sur un segment unique sans isolation.

À la suite d'un audit de sécurité, plusieurs vulnérabilités critiques ont été identifiées. La direction a donc exigé une refonte totale de l'architecture réseau afin de répondre aux impératifs suivants :

- **Isolation des services critiques** pour limiter les mouvements latéraux en cas de compromission.

- **Filtrage des accès web** pour protéger les employés contre les menaces en ligne.
- **Mise en place d'un accès distant sécurisé** pour permettre aux administrateurs de maintenir l'infrastructure en télétravail.

Mon rôle dans ce projet est d'agir en tant qu'administrateur réseaux et sécurité pour déployer une passerelle de sécurité basée sur la solution open-source **pfSense**, capable d'orchestrer cette nouvelle segmentation.

---

2. Architecture Réseau et Plan d'Adressage

2.1 Topologie Logique

L'architecture retenue repose sur une segmentation en trois zones distinctes, chacune ayant un rôle précis dans la politique de sécurité de Novacyber :

- **WAN (em0) :** Interface connectée à l'accès Internet (simulation via DHCP).
- **LAN (em1) :** Zone interne sécurisée accueillant les postes clients et le contrôleur de domaine Active Directory.
- **DMZ (em2) :** Zone démilitarisée isolant les serveurs exposés, tel que le serveur Web métier.

2.2 Plan d'Adressage IP

Conformément aux exigences techniques et aux relevés effectués sur la console pfSense, voici le plan d'adressage retenu pour l'infrastructure :

Interface	Zone	Réseau / Masque	IP pfSense	Description
WAN	Internet	192.168.1.0/24	192.168.1.33	Accès extérieur (DHCP)
LAN	Interne	172.16.60.0/24	172.16.60.254	Postes clients & AD
DMZ	Publique	10.60.60.0/24	10.60.60.1	Serveurs Web / Applicatifs

---

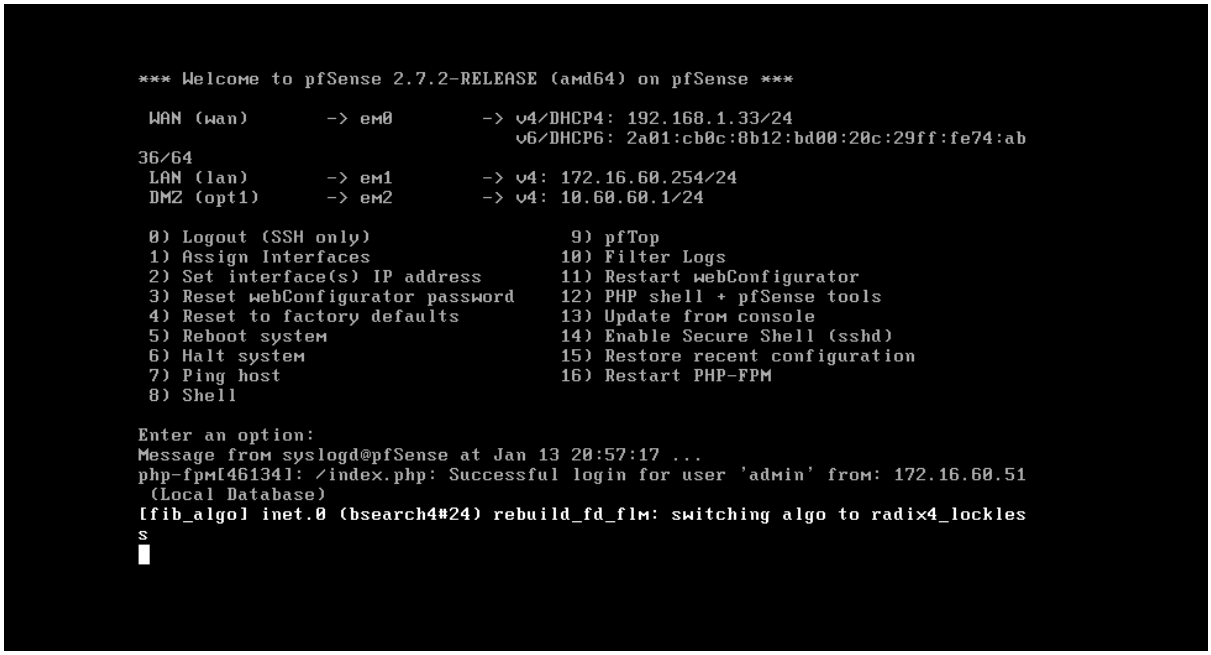
Ce plan d’adressage assure une séparation claire des flux et facilite l’application des règles de filtrage.

3. Installation et Configuration du Socle Réseau

3.1 Déploiement de pfSense

La première étape a consisté à installer pfSense 2.7.2-RELEASE sur une machine virtuelle VMware. Une fois l'installation terminée, j'ai procédé à l'assignation des interfaces réseau virtuelles aux interfaces logiques de pfSense.

Capture d'écran de la configuration des interfaces :



Cette capture d'écran correspond à l'interface console de **pfSense 2.7.2-RELEASE**, affichée après l'installation et la configuration initiale du pare-feu.

On y observe tout d'abord l'assignation correcte des interfaces réseau, élément fondamental du socle réseau :

- L'interface **WAN (em0)** est configurée en **DHCP**, ce qui permet à pfSense d'obtenir automatiquement une adresse IP depuis le réseau externe simulant l'accès Internet. L'adresse IPv4 attribuée est **192.168.1.33/24**, confirmant la connectivité vers le réseau WAN.
- L'interface **LAN (em1)** est configurée avec une adresse IP statique **172.16.60.254/24**, correspondant à la passerelle du réseau interne sécurisé. Cette interface est utilisée par les postes clients et le serveur Active Directory.

- L’interface **DMZ (em2)** dispose de l’adresse IP statique **10.60.60.1/24**, servant de passerelle pour la zone démilitarisée destinée à héberger les services exposés, notamment le serveur Web.

La présence de ces trois interfaces confirme la mise en place d’une **architecture réseau segmentée en trois zones distinctes (WAN / LAN / DMZ)**, conformément au cahier des charges du projet.

En bas de la capture, les logs système indiquent une **connexion réussie à l’interface web de pfSense** depuis l’adresse IP **172.16.60.51**, appartenant au réseau LAN. Cela valide :

- la connectivité entre un poste interne et pfSense,
- le bon fonction
-
-
- nement de l’interface d’administration Web,
- et la cohérence de l’adressage IP sur le réseau interne.

Cette étape constitue une base essentielle avant la mise en place des règles de pare-feu, des services avancés (LDAP, proxy) et des mécanismes de sécurité supplémentaires.

4. Sécurisation et Filtrage du Réseau

Dans le cadre de la sécurisation de l’architecture réseau de Novacyber, une politique de filtrage stricte a été mise en place sur le pare-feu pfSense.
Cette politique repose sur le **principe du moindre privilège**, qui consiste à n’autoriser que les flux strictement nécessaires au bon fonctionnement des services, tout en bloquant par défaut l’ensemble des autres communications.

Les règles de pare-feu ont été définies de manière granulaire sur chaque interface (LAN, DMZ et WAN), afin de contrôler précisément les flux autorisés entre les différentes zones du réseau.
Chaque règle est appliquée au plus proche de la source du trafic, conformément aux bonnes pratiques de sécurité.

Les sections suivantes détaillent les règles mises en place pour :

- autoriser l'accès Internet depuis le réseau interne (LAN),
- permettre les échanges nécessaires entre le LAN et la DMZ,
- empêcher toute communication initiée depuis la DMZ vers le LAN,
- restreindre l'accès depuis Internet aux seuls services exposés en DMZ.

Cette approche garantit une séparation stricte des zones, limite les risques de compromission et renforce la sécurité globale de l'infrastructure.

4.1 Règles de pare-feu strictes (Principe du moindre privilège)

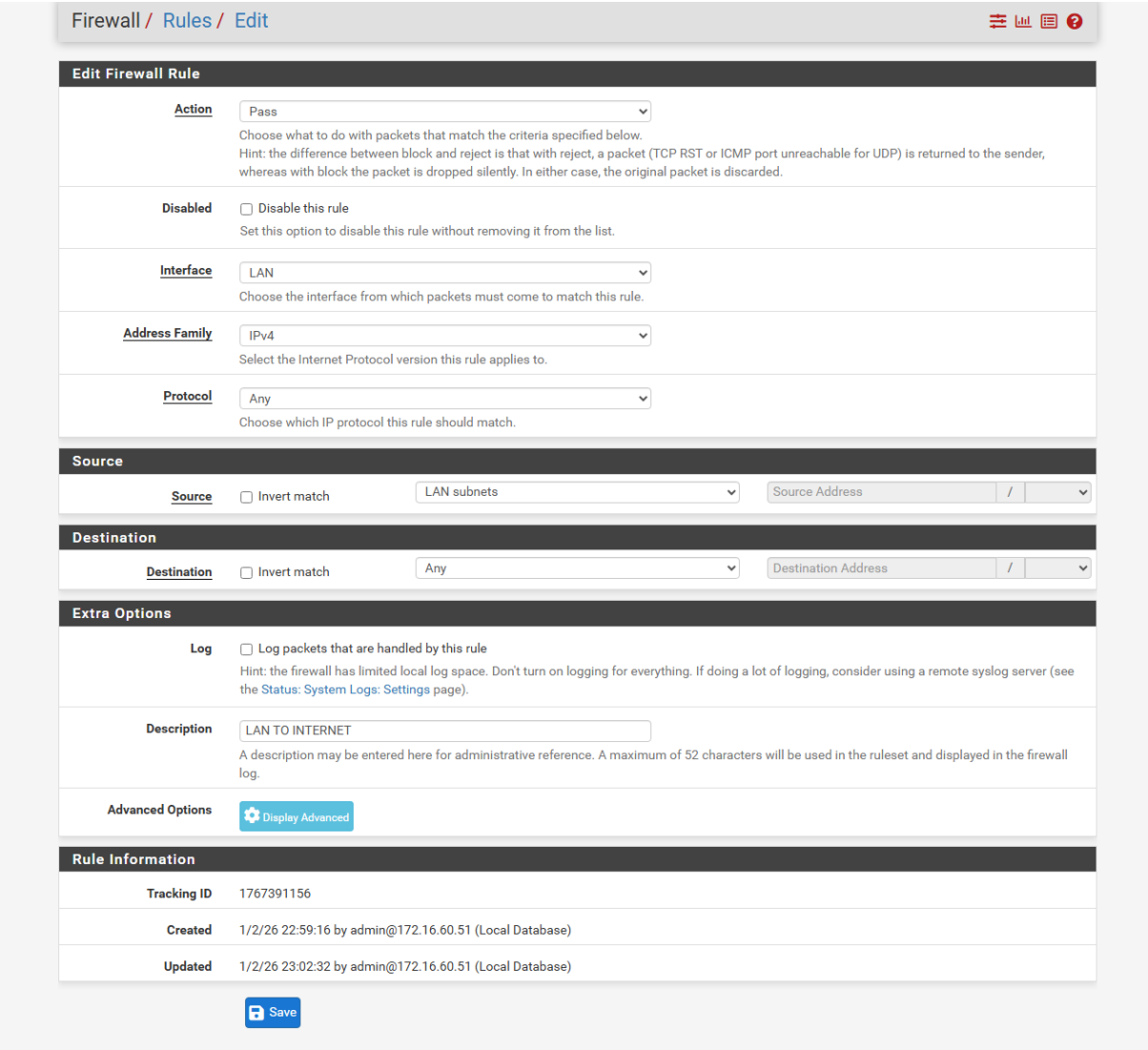
4.1.1 Le LAN peut accéder à Internet

Afin de permettre aux utilisateurs du réseau interne d'accéder aux ressources externes, une règle de pare-feu a été configurée sur l'interface **LAN** de pfSense.

Cette règle de type **PASS** autorise le trafic sortant provenant du réseau **LAN net** vers toutes les destinations. Elle permet notamment :

- la navigation web des postes utilisateurs,
- l'accès aux services en ligne nécessaires au fonctionnement de l'entreprise,
- la mise à jour des systèmes et applications.

Aucun accès entrant depuis le réseau WAN vers le LAN n'est autorisé, ce qui garantit la protection du réseau interne contre les connexions non sollicitées.
Cette règle respecte ainsi le **principe du moindre privilège**, en autorisant uniquement les flux sortants indispensables.



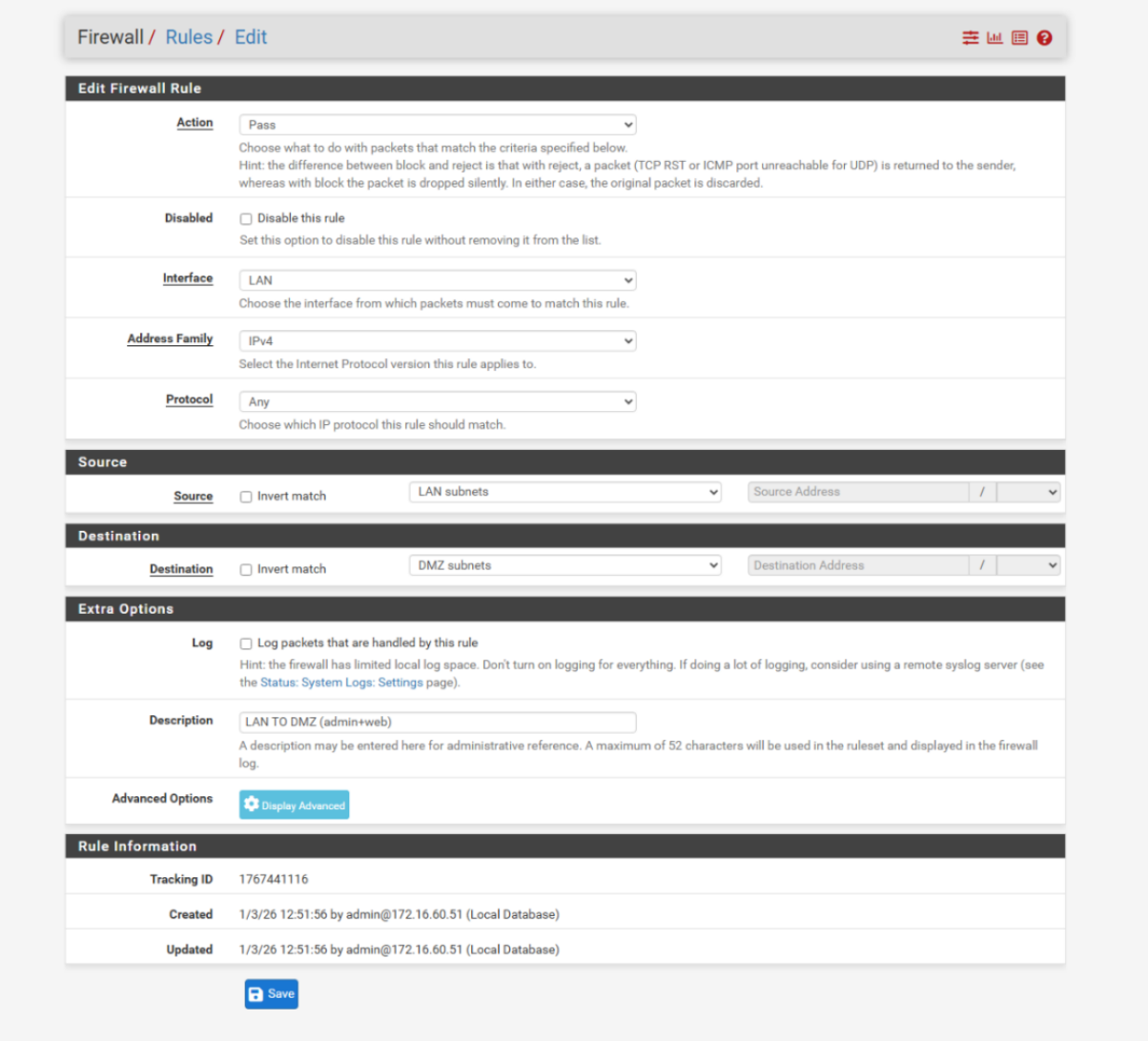
La capture ci-dessus présente la configuration détaillée de la règle de pare-feu mise en place sur l'interface **LAN** de pfSense afin d'autoriser l'accès à Internet pour les postes internes.

Cette règle est configurée avec les paramètres suivants :

- **Action** : Pass
- **Interface** : LAN
- **Protocole** : Any
- **Source** : LAN subnets
- **Destination** : Any

Cette configuration permet à l'ensemble des machines du réseau interne d'émettre des connexions vers Internet, quel que soit le protocole utilisé, tout en conservant une politique de filtrage stricte sur les autres interfaces.

La règle est volontairement appliquée uniquement sur l'interface LAN, ce qui empêche tout accès entrant non sollicité depuis le réseau WAN vers le réseau interne.
Elle respecte ainsi le **principe du moindre privilège**, en autorisant exclusivement les flux sortants nécessaires au fonctionnement des utilisateurs et des services internes.



Afin de permettre l'administration et la consultation des services hébergés en zone démilitarisée, une règle de pare-feu spécifique a été configurée sur l'interface **LAN** de pfSense.

La capture ci-dessous présente la configuration détaillée de cette règle de filtrage.
Elle autorise le trafic provenant du réseau **LAN** à destination du réseau **DMZ**, tout en conservant une séparation stricte entre les deux zones.

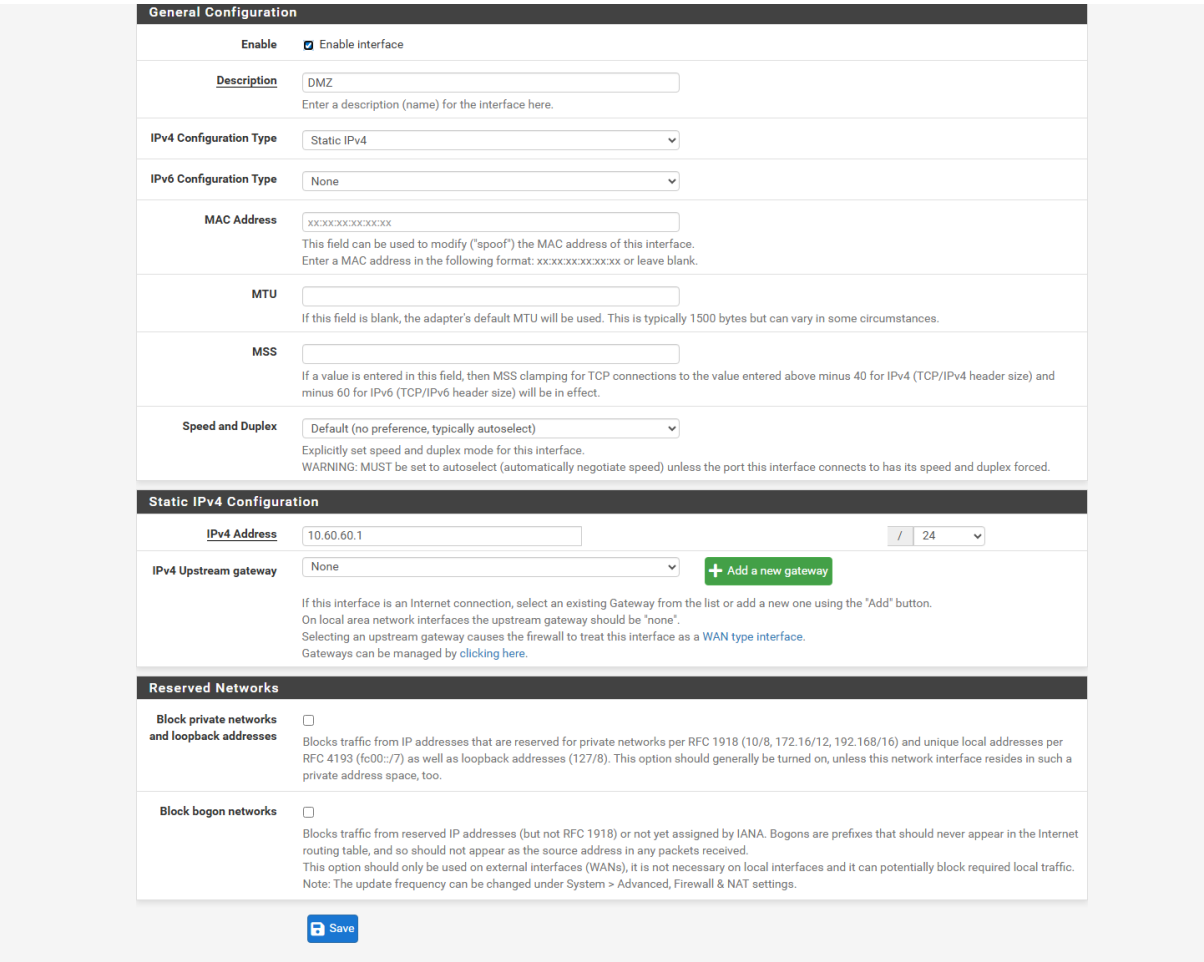
Les paramètres de la règle sont les suivants :

- **Action** : Pass
- **Interface** : LAN
- **Famille d'adresses** : IPv4
- **Protocole** : Any
- **Source** : LAN subnets
- **Destination** : DMZ subnets

Cette règle permet notamment :

- l'accès des administrateurs aux services hébergés en DMZ,
- la consultation du serveur web exposé,
- les opérations de maintenance depuis le réseau interne.

La règle est volontairement limitée au sens **LAN → DMZ**.
Aucune règle inverse n'est autorisée, ce qui empêche tout flux initié depuis la DMZ vers le LAN. Cette approche respecte pleinement le **principe du moindre privilège** et réduit les risques de propagation en cas de compromission d'un service exposé.



3.2 Configuration de l'interface DMZ

La capture ci-dessous présente la configuration de l'interface DMZ sur le pare-feu pfSense. Cette interface représente la zone démilitarisée, destinée à héberger les services exposés vers l'extérieur, tout en restant isolée du réseau interne.

L'interface DMZ est activée et configurée avec une adresse IPv4 statique, conformément au plan d'adressage défini pour l'architecture réseau.

Les paramètres principaux sont les suivants :

- **Interface activée : Oui**
- **Description : DMZ**
- **Type de configuration IPv4 : Static IPv4**

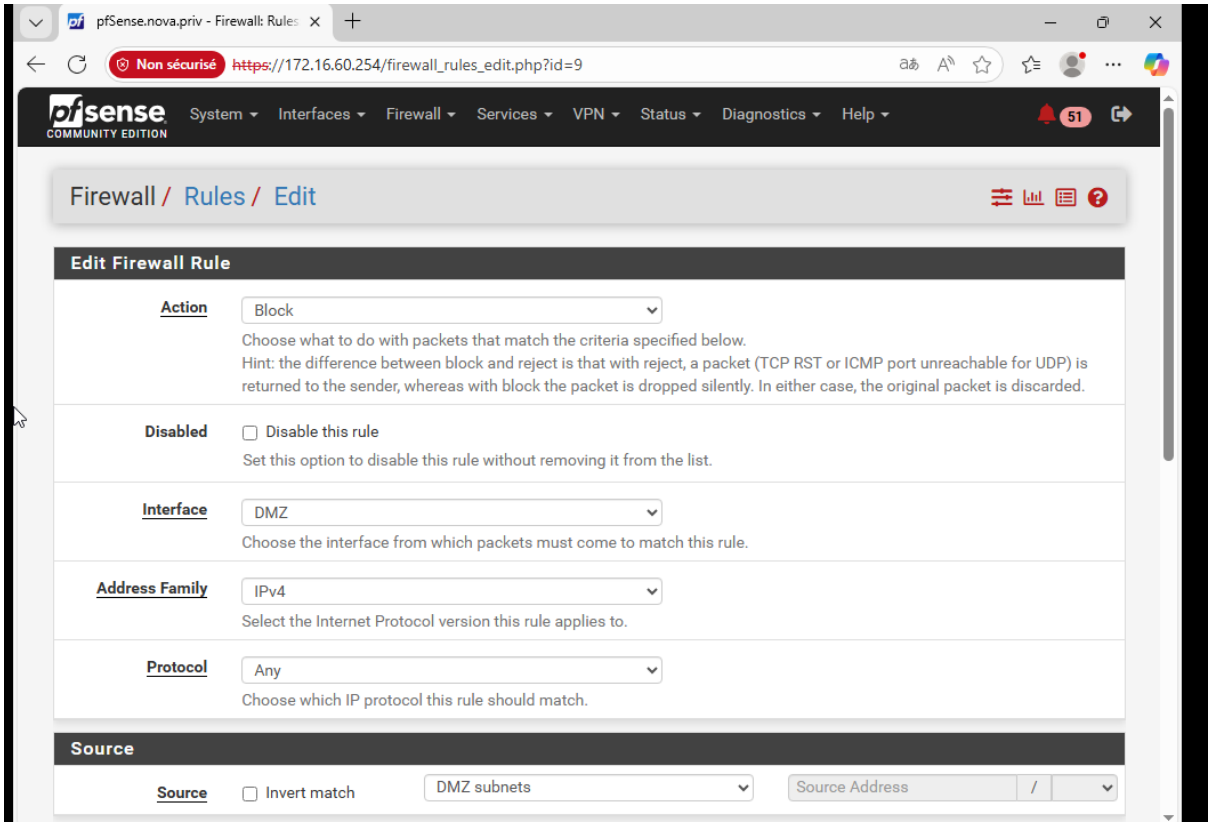
- **Adresse IPv4 : 10.60.60.1 /24**
- **Passerelle amont (Upstream Gateway) : Aucune**

L'absence de passerelle sur cette interface garantit que la DMZ ne soit pas considérée comme une interface de type WAN, ce qui renforce l'isolation entre les différentes zones du réseau.

Les options de blocage des réseaux privés et bogon ne sont pas activées sur cette interface, la DMZ utilisant volontairement un plan d'adressage privé pour les serveurs exposés dans le cadre de cette architecture.

Cette configuration permet à pfSense de jouer le rôle de passerelle sécurisée pour la DMZ, tout en assurant un contrôle strict des flux via les règles de pare-feu mises en place ultérieurement.

4.1.3 La DMZ ne doit jamais initier de connexion vers le LAN



Afin de garantir l'isolement strict entre la zone démilitarisée (DMZ) et le réseau interne (LAN), une règle de pare-feu restrictive a été mise en place sur l'interface **DMZ** de pfSense.

La capture ci-dessous présente la configuration de cette règle de sécurité.
Il s'agit d'une règle de type **BLOCK**, appliquée directement à la source du trafic, empêchant toute communication initiée depuis la DMZ vers le LAN.

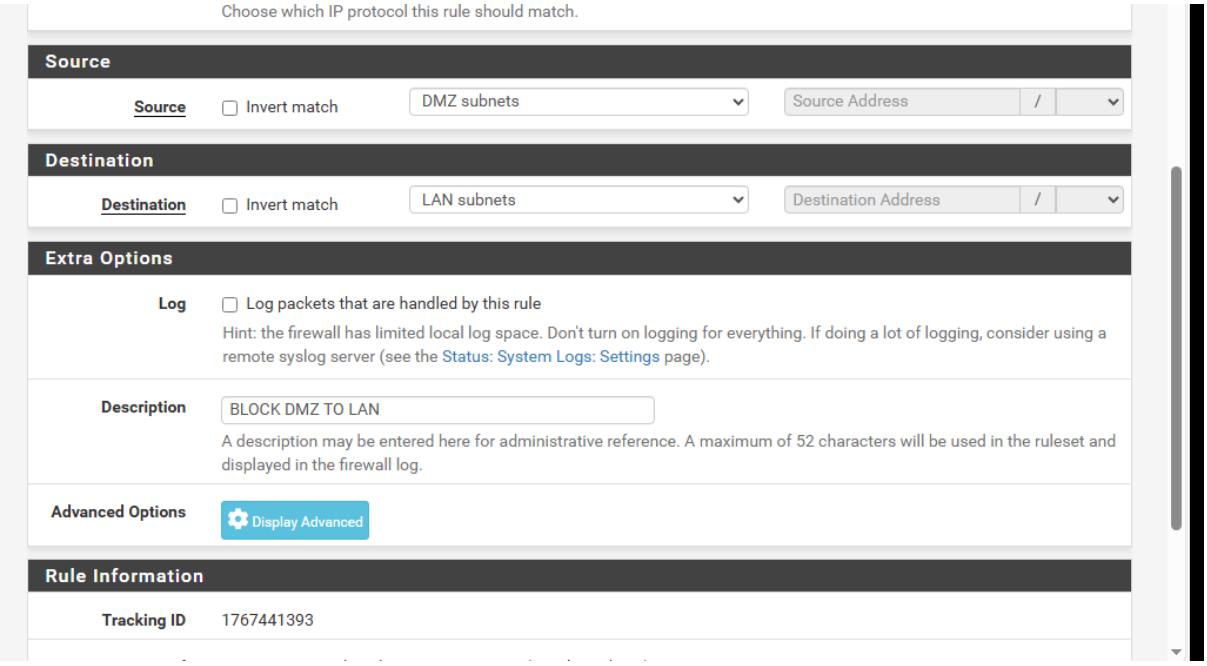
Les paramètres de la règle sont les suivants :

- **Action** : Block
- **Interface** : DMZ
- **Famille d'adresses** : IPv4

- **Protocole** : Any
- **Source** : DMZ subnets
- **Destination** : LAN subnets

Cette règle empêche tout serveur exposé en DMZ d'établir une connexion vers le réseau interne, même en cas de compromission du service.
Elle constitue une mesure de sécurité essentielle visant à limiter les **mouvements latéraux** et à protéger les ressources critiques hébergées sur le LAN.

Cette configuration respecte strictement le **principe du moindre privilège**, en interdisant tout flux inutile ou dangereux entre les deux zones.

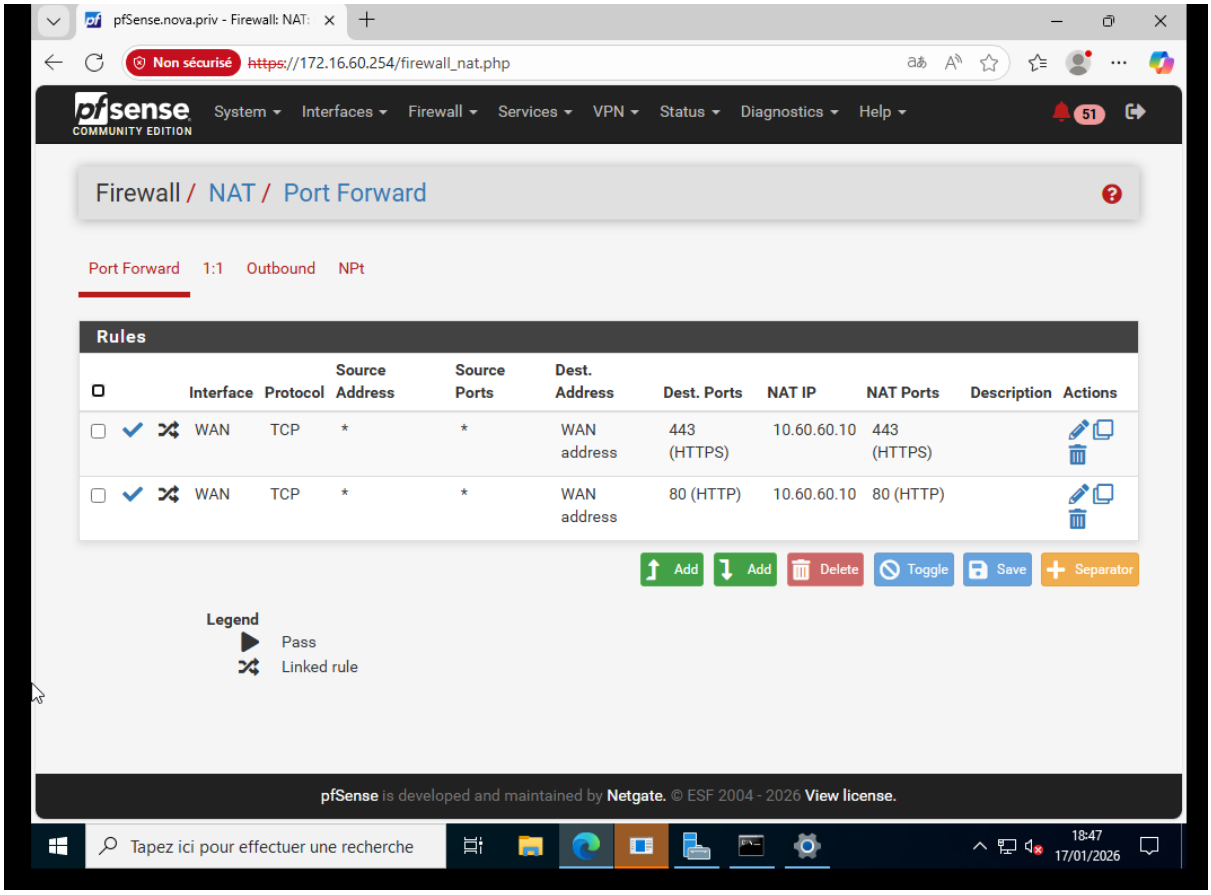


La capture ci-dessus montre le paramétrage précis de la règle de pare-feu appliquée sur l'interface **DMZ**.
La source du trafic est définie comme **DMZ subnets**, tandis que la destination correspond aux **LAN subnets**, ce qui permet de bloquer explicitement toute tentative de communication entre ces deux zones.

La règle est configurée de manière globale, sans restriction de protocole, afin de garantir un blocage total, quel que soit le type de trafic concerné.
Le champ de description *« BLOCK DMZ TO LAN »* facilite l'identification et la maintenance de cette règle dans la politique de filtrage.

Cette configuration empêche efficacement tout serveur situé en DMZ d'initier une connexion vers le réseau interne.
Elle constitue une mesure de sécurité essentielle permettant de contenir une éventuelle compromission d'un service exposé et d'éviter toute propagation vers le LAN.

4.1.4 Le WAN accède uniquement au serveur Web en DMZ (NAT / Port Forwarding)



Afin de permettre l'accès aux services web hébergés en zone démilitarisée depuis Internet, des règles de **NAT de type Port Forwarding** ont été configurées sur l'interface **WAN** de pfSense.

La capture ci-dessous présente les règles de redirection mises en place.
Elles autorisent exclusivement les connexions entrantes provenant du réseau WAN vers le serveur Web situé en DMZ, sur les ports **80 (HTTP)** et **443 (HTTPS)**.

Les paramètres principaux des règles sont les suivants :

- **Interface** : WAN
- **Protocole** : TCP
- **Adresse de destination** : WAN address
- **Ports de destination** : 80 (HTTP) et 443 (HTTPS)
- **Adresse de redirection (NAT IP)** : 10.60.60.10 (serveur Web en DMZ)
- **Ports de redirection** : 80 et 443

Ces règles permettent de publier le service Web vers l'extérieur tout en limitant strictement les ports accessibles.
Aucun autre service ou port n'est exposé depuis le WAN, ce qui garantit une surface d'attaque minimale.

Les règles de filtrage associées sur l'interface WAN sont automatiquement générées par pfSense, assurant ainsi la cohérence entre la translation d'adresses (NAT) et la politique de pare-feu.

Cette configuration respecte pleinement le **principe du moindre privilège**, en n'autorisant que les flux strictement nécessaires à l'exposition du service Web.

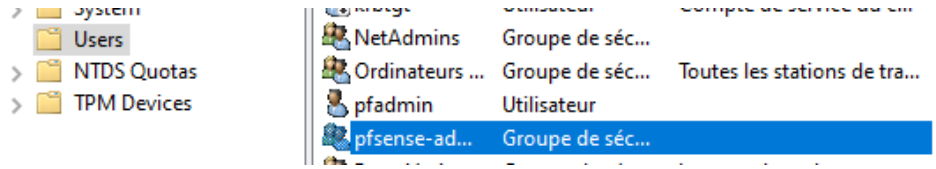
Phase 2 : Gestion des Identités et Proxy

2.1 Liaison LDAP avec l'Active Directory

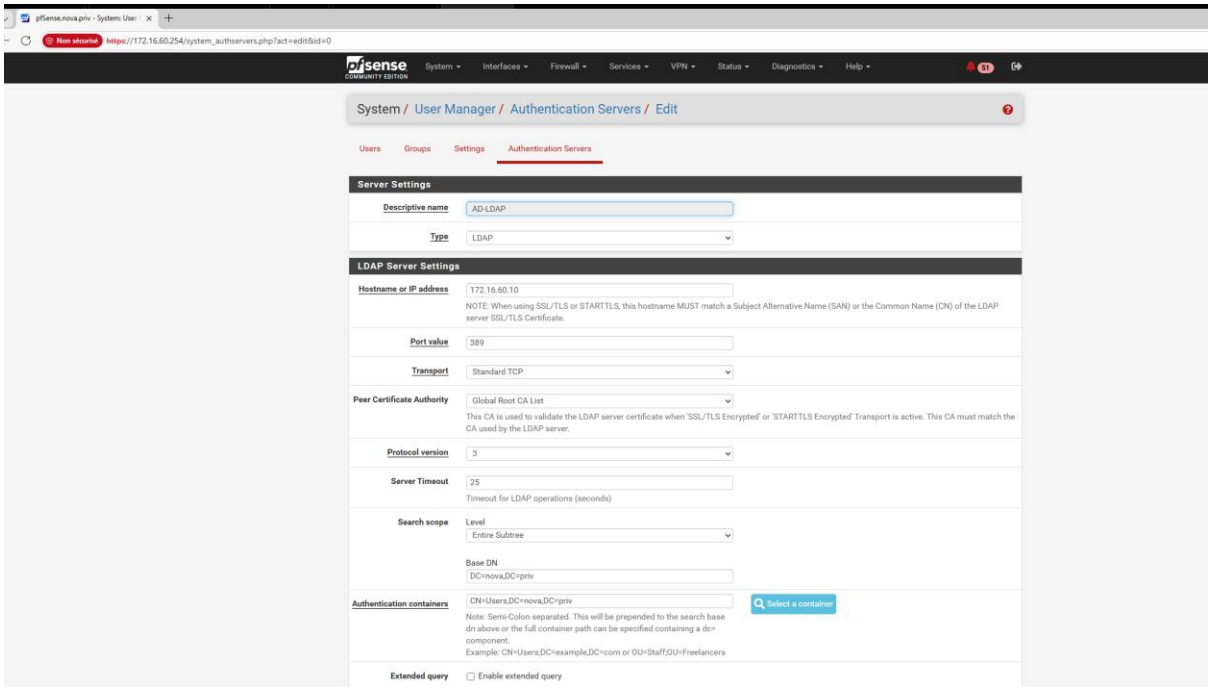
Centraliser l'authentification des administrateurs de pfSense sur l'Active Directory afin d'éviter l'utilisation de comptes locaux et de renforcer la sécurité.

Dans le cadre de la gestion des identités, pfSense a été configuré pour s'interfacer avec l'**Active Directory** de l'entreprise via le protocole **LDAP**.
Cette intégration permet de centraliser l'authentification des utilisateurs et de s'appuyer sur l'annuaire existant pour la gestion des accès administrateurs au pare-feu.

Un groupe dédié nommé **pfsense-admins** a été créé dans l'Active Directory.
Ce groupe a pour rôle de regrouper exclusivement les utilisateurs autorisés à administrer pfSense.



Ensuite, un serveur d'authentification LDAP a été configuré dans pfSense afin d'établir la communication avec le contrôleur de domaine.
Les paramètres nécessaires (adresse du serveur, base DN, compte de liaison) ont été renseignés, puis un test d'authentification a été effectué afin de valider le bon fonctionnement de la liaison LDAP.



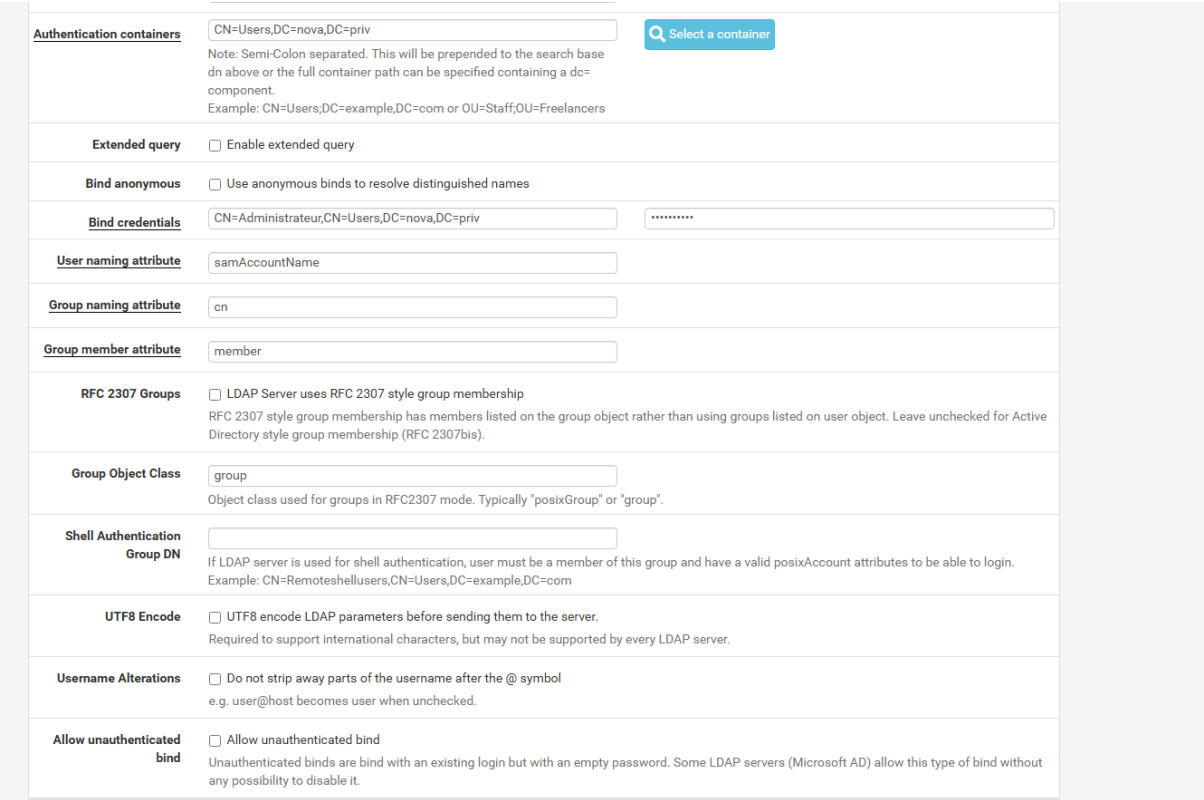
La capture ci-dessus présente la configuration du serveur d'authentification **LDAP** dans pfSense afin d'établir la communication avec le contrôleur de domaine Active Directory.

Un serveur d'authentification nommé **AD-LDAP** a été ajouté et configuré avec les paramètres suivants :

- **Type** : LDAP
- **Adresse du serveur** : 172.16.60.10 (contrôleur de domaine Active Directory)
- **Port** : 389 (LDAP standard)
- **Transport** : TCP standard
- **Version du protocole LDAP** : 3
- **Base DN** : DC=nova,DC=priv
- **Conteneur d'authentification** : CN=Users,DC=nova,DC=priv

Ces paramètres permettent à pfSense d'interroger l'annuaire Active Directory afin d'authentifier les utilisateurs du domaine.
Un compte de liaison (Bind DN) a été utilisé pour permettre la consultation de l'annuaire.

Une fois la configuration effectuée, un test d'authentification a été réalisé avec un compte Active Directory afin de valider le bon fonctionnement de la liaison LDAP.



La capture ci-dessus présente les paramètres avancés utilisés pour l'intégration de pfSense avec l'Active Directory via LDAP.

Le conteneur d'authentification a été défini sur **CN=Users,DC=nova,DC=priv**, ce qui permet à pfSense de rechercher les comptes utilisateurs directement dans l'unité d'organisation par défaut de l'annuaire Active Directory.

L'authentification LDAP s'appuie sur un **compte de liaison (Bind DN)** disposant des droits nécessaires à la lecture de l'annuaire.
Ce compte permet à pfSense d'interroger l'Active Directory afin de valider les identifiants des utilisateurs lors de la connexion.

Les attributs LDAP suivants ont été configurés :

- **Attribut de nom d'utilisateur** : samAccountName, correspondant au nom de connexion des utilisateurs Active Directory
- **Attribut de nom de groupe** : cn
- **Attribut d'appartenance aux groupes** : member

Ces paramètres sont conformes au fonctionnement standard de Microsoft Active Directory (RFC 2307bis), garantissant une identification correcte des utilisateurs et de leur appartenance aux groupes.

Aucune authentification anonyme n'a été autorisée et les options non nécessaires ont été laissées désactivées, afin de limiter les accès et de renforcer la sécurité de la liaison LDAP.

Cette configuration permet à pfSense de s'intégrer proprement à l'Active Directory et constitue une base fiable pour l'attribution des droits d'administration au groupe **pfsense-admins**.

2.1.2 Attribution des droits d'administration pfSense via l'Active Directory

Afin de contrôler l'accès à l'interface d'administration du pare-feu, un groupe distant issu de l'Active Directory a été configuré dans pfSense.

Un groupe nommé **LDAPS-ADMIN** a été créé avec un **scope Remote**, ce qui permet à pfSense d'utiliser directement les groupes et utilisateurs provenant de l'annuaire Active Directory.
Ce groupe correspond au groupe **pfsense-admins** défini dans l'Active Directory.

Les utilisateurs membres de ce groupe sont automatiquement reconnus par pfSense lors de l'authentification LDAP.
Le groupe a ensuite été associé au privilège **WebCfg – All pages**, donnant un accès complet à l'interface d'administration du pare-feu.

Cette configuration permet :

- de **centraliser la gestion des droits** dans l'Active Directory,
- de **limiter l'accès administrateur** aux seuls membres du groupe autorisé,
- de supprimer la nécessité de gérer des comptes administrateurs locaux sur pfSense.

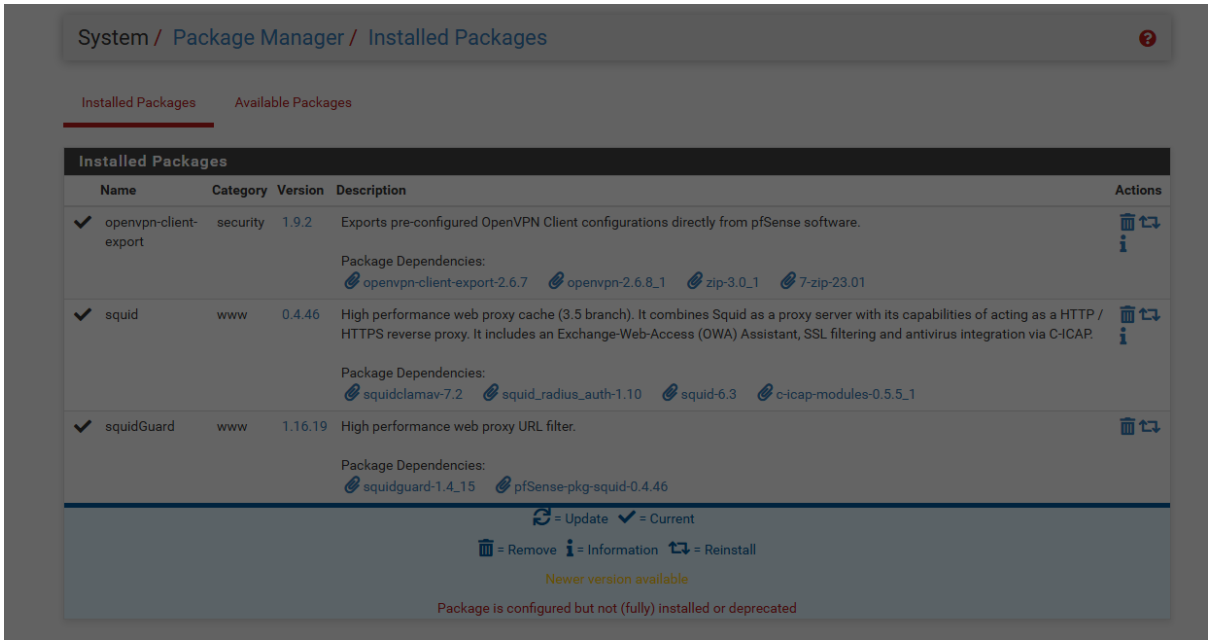
L'utilisation d'un groupe distant pour l'administration du pare-feu renforce la sécurité, la traçabilité des connexions et s'inscrit dans une logique de **gestion des identités centralisée**.

2.2 Proxy Web (Squid)

2.2.1 Mise en place du proxy transparent

Le service Squid a été installé et activé sur pfSense.
Le proxy est configuré pour intercepter le trafic web provenant du réseau LAN sur les ports HTTP (80) et HTTPS (443).

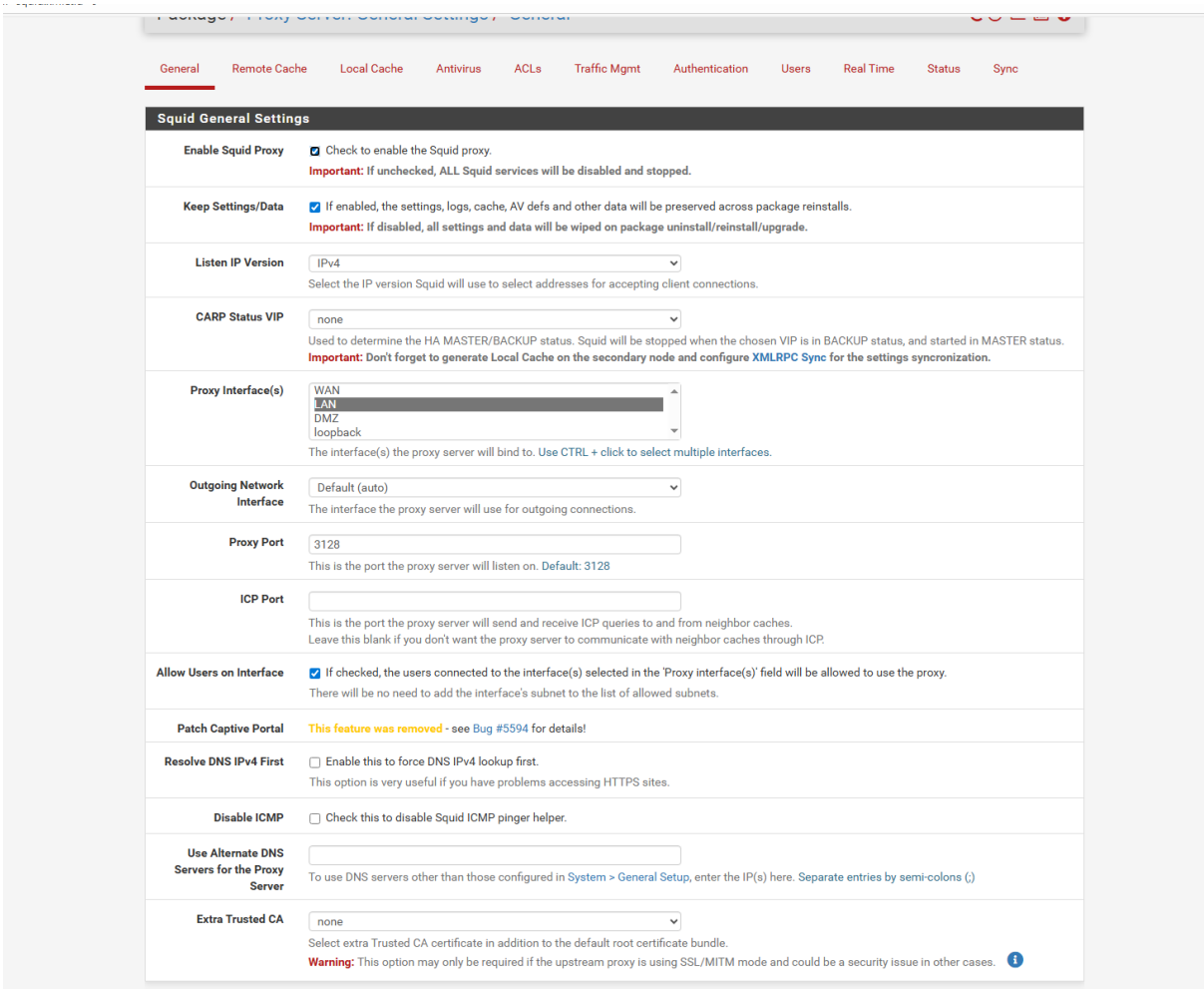
L'interface LAN est utilisée comme interface d'écoute du proxy afin de rediriger automatiquement le trafic web des utilisateurs vers le service Squid.



Afin de mettre en place un contrôle des accès web pour le réseau interne, les packages **Squid** et **SquidGuard** ont été installés sur le pare-feu pfSense via le gestionnaire de paquets.

- **Squid** est utilisé comme proxy web HTTP/HTTPS afin d'intercepter et contrôler les flux Internet sortants.
- **SquidGuard** est utilisé comme module de filtrage d'URL permettant d'appliquer des règles de restriction d'accès aux sites web (catégories, domaines interdits, etc.).

L'installation de ces services constitue la base de la mise en œuvre d'un proxy web sécurisé et contrôlé pour le réseau LAN.

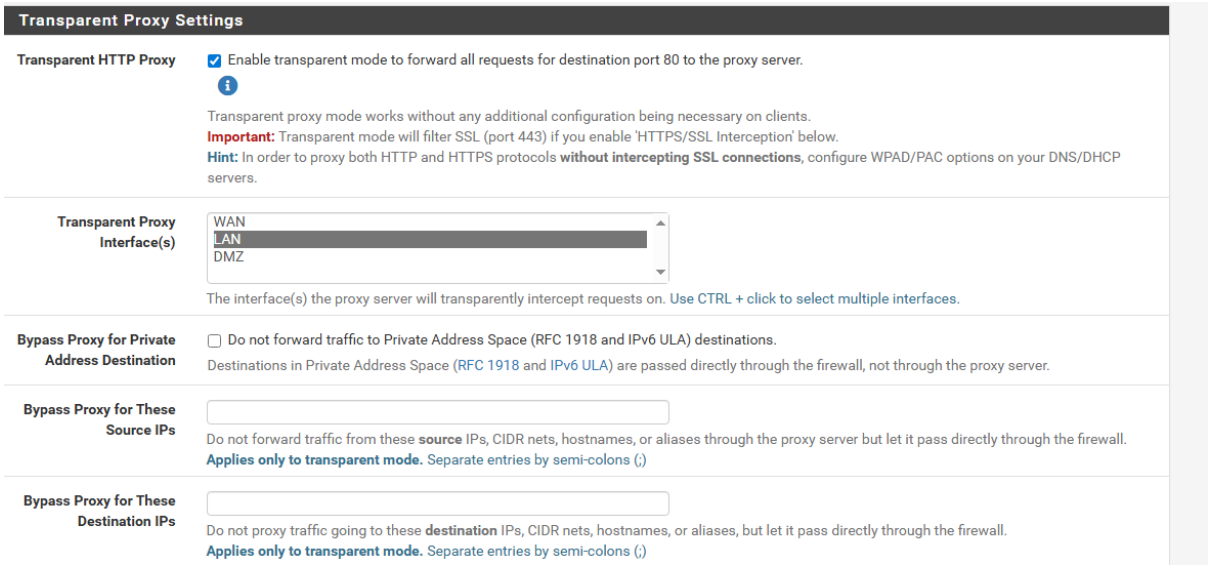


Cette capture présente la configuration générale du proxy Squid sur le pare-feu pfSense.

Le service Squid est activé afin de mettre en place un point de contrôle centralisé des accès web. Le proxy fonctionne en IPv4 et écoute uniquement sur l'interface LAN, ce qui garantit que seuls les postes du réseau interne peuvent utiliser le proxy.

Le trafic sortant est automatiquement redirigé vers l'interface WAN, assurant un accès Internet contrôlé sans configuration spécifique sur les postes clients. Le port d'écoute du proxy est conservé à sa valeur par défaut (3128). L'option autorisant les utilisateurs connectés à l'interface LAN à utiliser le proxy est activée, facilitant le déploiement tout en maintenant un niveau de sécurité élevé.

Cette configuration constitue la base du filtrage web, qui sera renforcée par la mise en place de règles de filtrage d'URL et de contrôle HTTPS.

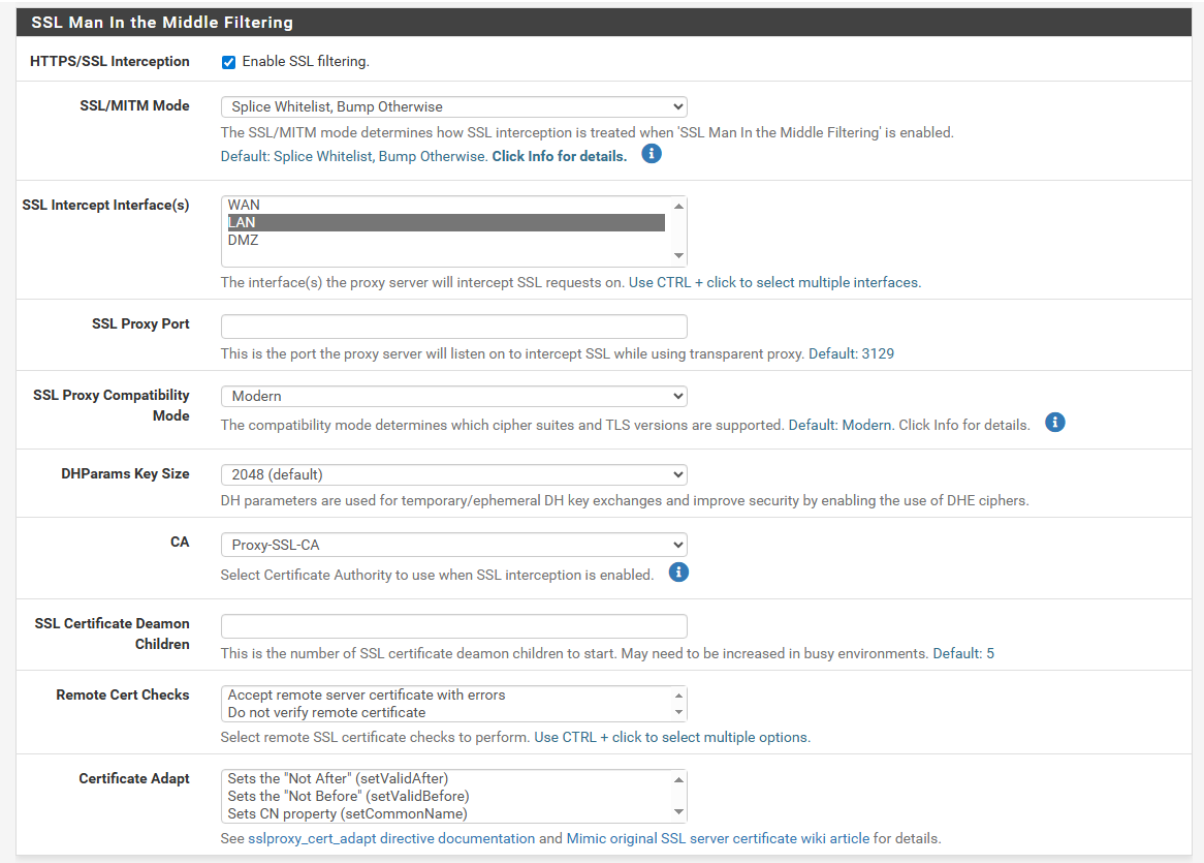


Cette capture présente la configuration du mode proxy transparent du service Squid sur pfSense.

Le mode proxy transparent HTTP est activé afin d'intercepter automatiquement les requêtes web à destination du port 80, sans nécessiter de configuration spécifique sur les postes clients. Ce fonctionnement permet une intégration totalement transparente pour les utilisateurs du réseau LAN. Le proxy transparent est appliqué uniquement sur l'interface LAN, garantissant que seul le trafic web interne est intercepté et analysé. Les interfaces WAN et DMZ ne sont pas concernées par ce mécanisme, ce qui respecte la segmentation réseau mise en place.

Les options de contournement du proxy pour les adresses privées et certaines destinations spécifiques ne sont pas activées, afin de conserver un contrôle centralisé et cohérent du trafic HTTP.

Cette configuration permet de préparer efficacement la mise en œuvre du filtrage web, notamment via des règles de filtrage d'URL et de contrôle d'accès applicatif.



Cette capture présente la configuration de l'interception HTTPS (SSL Man-in-the-Middle) du proxy Squid sur pfSense.

Le filtrage SSL est activé afin de permettre l'analyse et le contrôle du trafic HTTPS, qui représente aujourd'hui la majorité des communications web. Le mode « Splice Whitelist, Bump Otherwise » est utilisé : les sites explicitement autorisés ne sont pas interceptés, tandis que les autres connexions HTTPS sont déchiffrées temporairement pour permettre l'application des règles de filtrage.

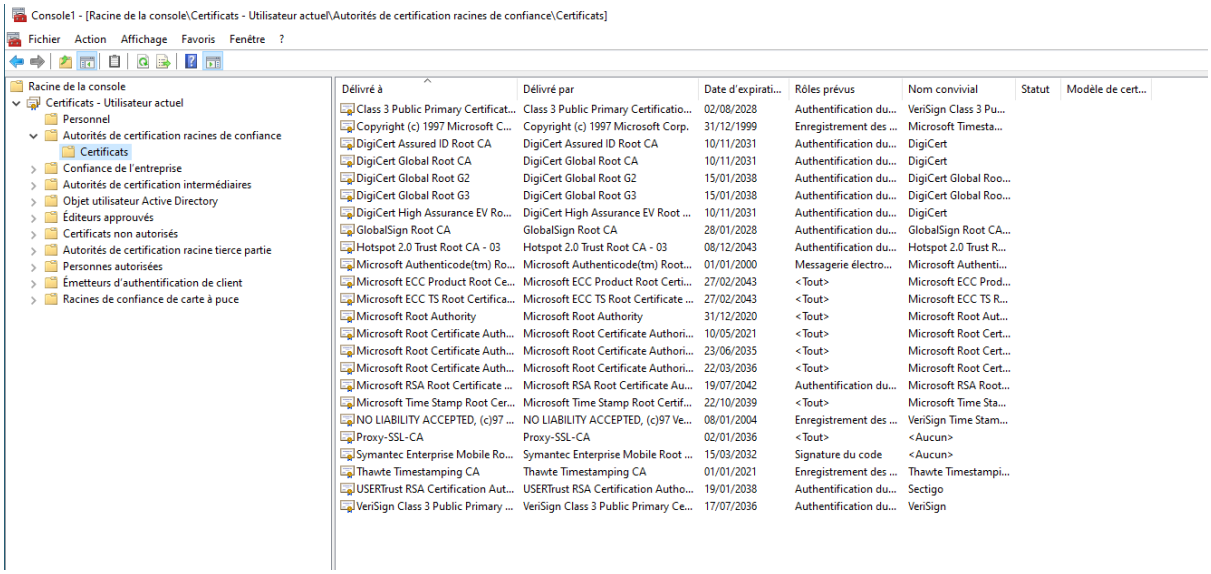
L'interception SSL est appliquée uniquement sur l'interface LAN, garantissant que seuls les flux HTTPS internes sont concernés. Les interfaces WAN et DMZ ne sont pas impactées, conformément à la segmentation réseau mise en place.

Une autorité de certification interne (Proxy-SSL-CA) est utilisée pour signer dynamiquement les certificats présentés aux clients. Cette autorité est déployée sur les postes clients afin d'éviter les alertes de sécurité dans les navigateurs.

Le niveau de compatibilité SSL est configuré en mode moderne, assurant l'utilisation de protocoles et de suites cryptographiques sécurisées.

Cette configuration permet de filtrer efficacement les sites HTTPS, notamment les réseaux sociaux et les sites malveillants, tout en conservant un haut niveau de sécurité.

Déploiement de l’autorité de certification du proxy sur les postes clients

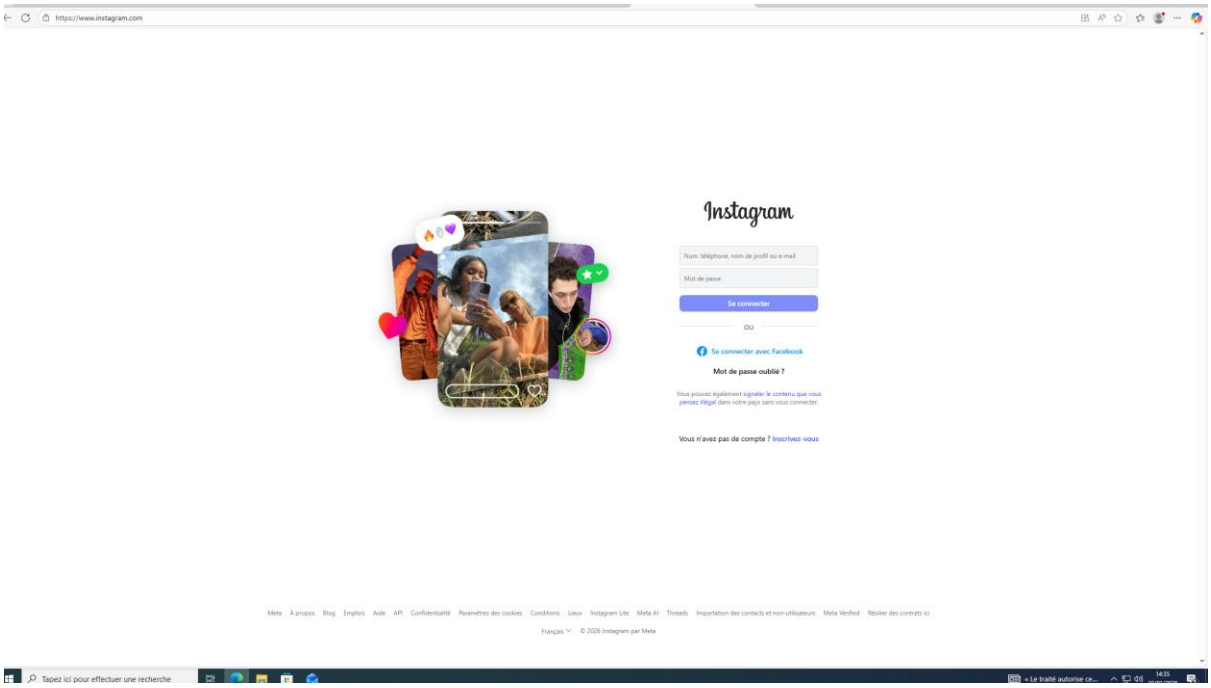


Cette capture montre l’importation de l’autorité de certification interne du proxy (Proxy-SSL-CA) dans le magasin des autorités de certification racines de confiance du poste client.

Cette étape est indispensable pour permettre l’interception HTTPS (SSL Man-in-the-Middle) sans générer d’alertes de sécurité dans les navigateurs. En faisant confiance à l’autorité Proxy-SSL-CA, le poste client accepte les certificats générés dynamiquement par le proxy Squid lors de l’analyse du trafic HTTPS.

L’autorité de certification est installée dans le magasin « Autorités de certification racines de confiance », garantissant qu’elle est reconnue par l’ensemble des applications et navigateurs du système.

Cette configuration permet d’assurer un filtrage HTTPS transparent pour l’utilisateur tout en conservant un haut niveau de sécurité et de contrôle des accès web.

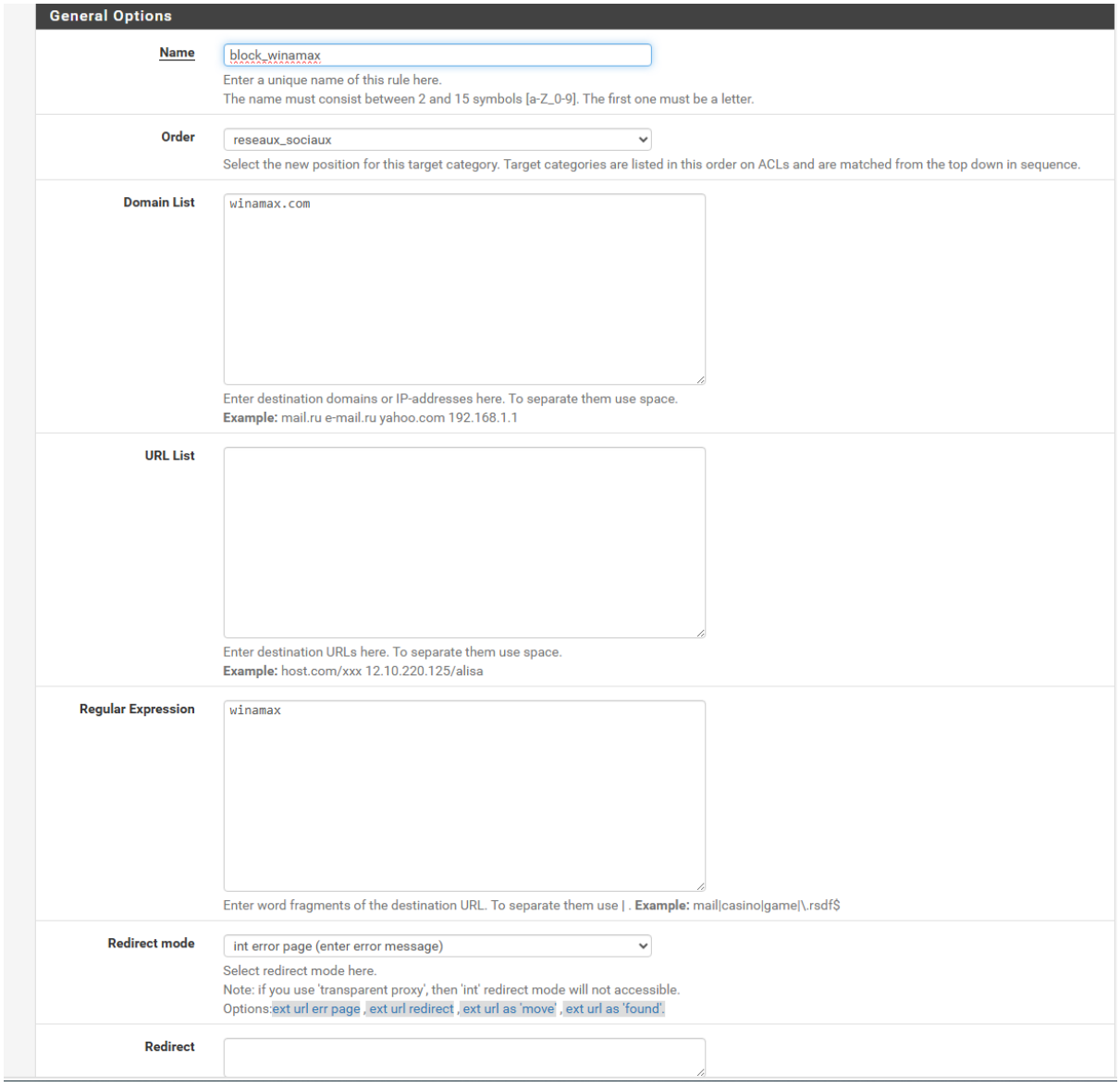


Cette capture d'écran montre l'accès au site Instagram via le protocole HTTPS depuis un poste client du réseau LAN.

Le cadenas de sécurité visible dans la barre d'adresse du navigateur indique que la connexion est bien chiffrée et que le certificat SSL présenté au client est reconnu comme valide. Cela confirme que l'autorité de certification interne du proxy (Proxy-SSL-CA), précédemment importée sur le poste client, est correctement prise en compte par le système.Malgré la mise en place de l'interception HTTPS (SSL Man-in-the-Middle) par le proxy Squid, aucune alerte de sécurité n'est affichée par le navigateur. Le proxy est donc en mesure d'analyser et de filtrer le trafic HTTPS tout en maintenant une connexion sécurisée et transparente pour l'utilisateur.

Cette observation valide le bon fonctionnement de la chaîne complète de sécurisation : interception SSL, déploiement de l'autorité de certification sur les postes clients et continuité du chiffrement des communications web.

2.2.2 Filtrage Web et Contrôle des Accès Internet (Squid / SquidGuard)

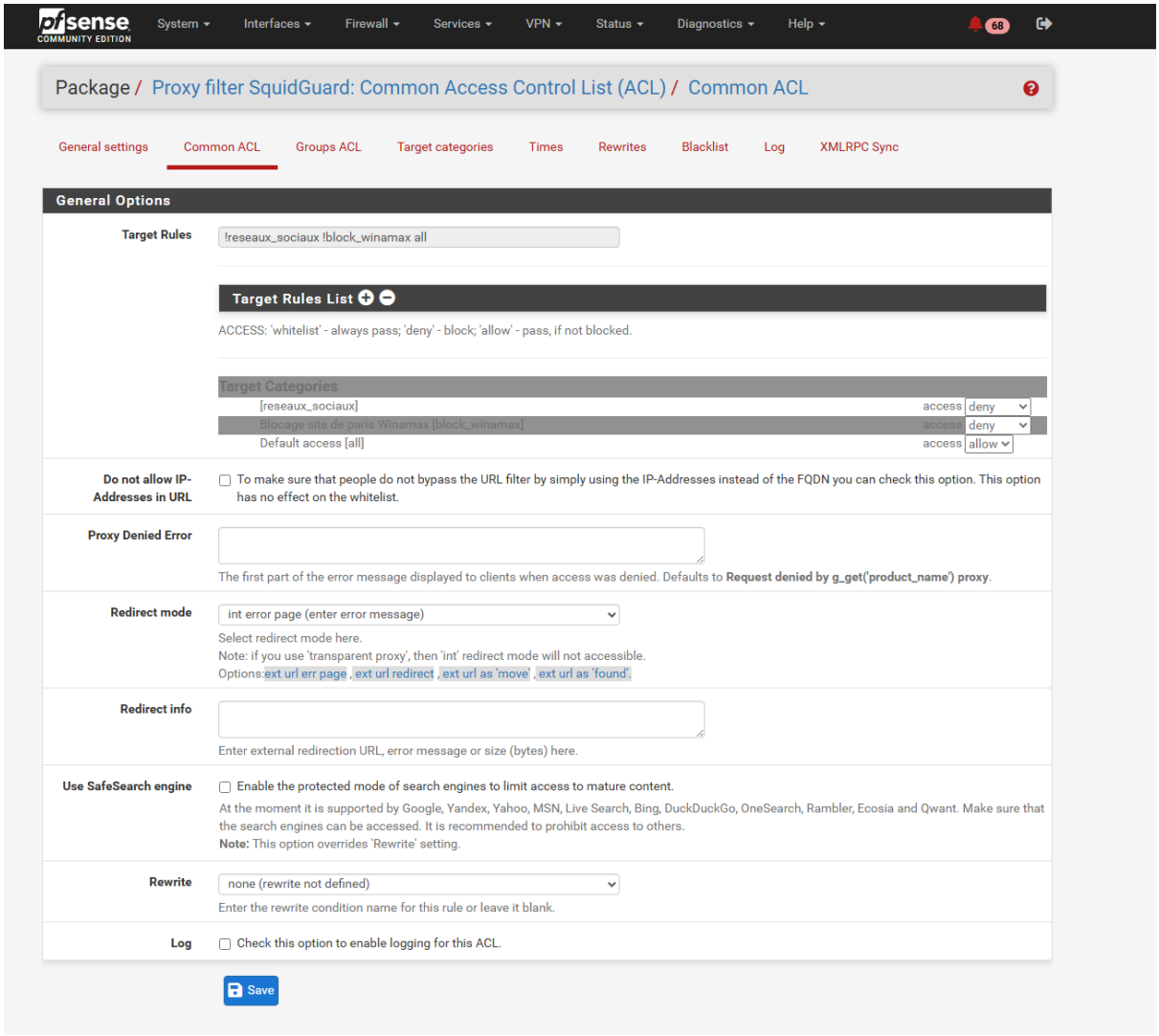


Dans le cadre de la sécurisation du réseau, un filtrage des sites web a été mis en place afin de limiter l'accès à certains contenus considérés comme non professionnels ou inappropriés. Cette configuration a été réalisée sur le pare-feu pfSense à l'aide du proxy Squid et de l'extension SquidGuard, qui permet de contrôler les accès Internet des utilisateurs du réseau interne.

Le principe du filtrage repose sur l'analyse des requêtes web émises par les postes clients du LAN. Lorsqu'un utilisateur tente d'accéder à un site Internet, la requête passe d'abord par le proxy Squid, qui la transmet ensuite à SquidGuard. SquidGuard compare alors l'adresse

demandée avec des règles de filtrage définies par l'administrateur. En fonction de ces règles, l'accès est soit autorisé, soit refusé.

Pour bloquer un site précis, une catégorie de filtrage a été créée dans SquidGuard. Cette catégorie permet de regrouper les domaines ou mots-clés correspondant au site à bloquer. Dans le cas présent, le site Winamax a été ciblé afin d'empêcher l'accès aux sites de jeux d'argent depuis le réseau de l'entreprise. Le domaine winamax.com a été ajouté dans la liste des domaines à bloquer, et une expression régulière contenant le mot "winamax" a également été utilisée afin de bloquer les sous-domaines et les éventuelles variantes du site.



Dans cette étape, la configuration du filtrage web est finalisée au niveau de la liste de contrôle d'accès globale, appelée *Common ACL*, dans SquidGuard. Cette partie permet de définir quelles catégories de sites sont autorisées ou bloquées pour l'ensemble des utilisateurs du réseau.

Les catégories créées précédemment, comme celle destinée au blocage du site Winamax ou celle regroupant les réseaux sociaux, apparaissent dans la section *Target Categories*. Chaque catégorie est associée à une action précise, qui détermine le comportement du proxy lorsqu'un utilisateur tente d'accéder à un site correspondant à cette catégorie.

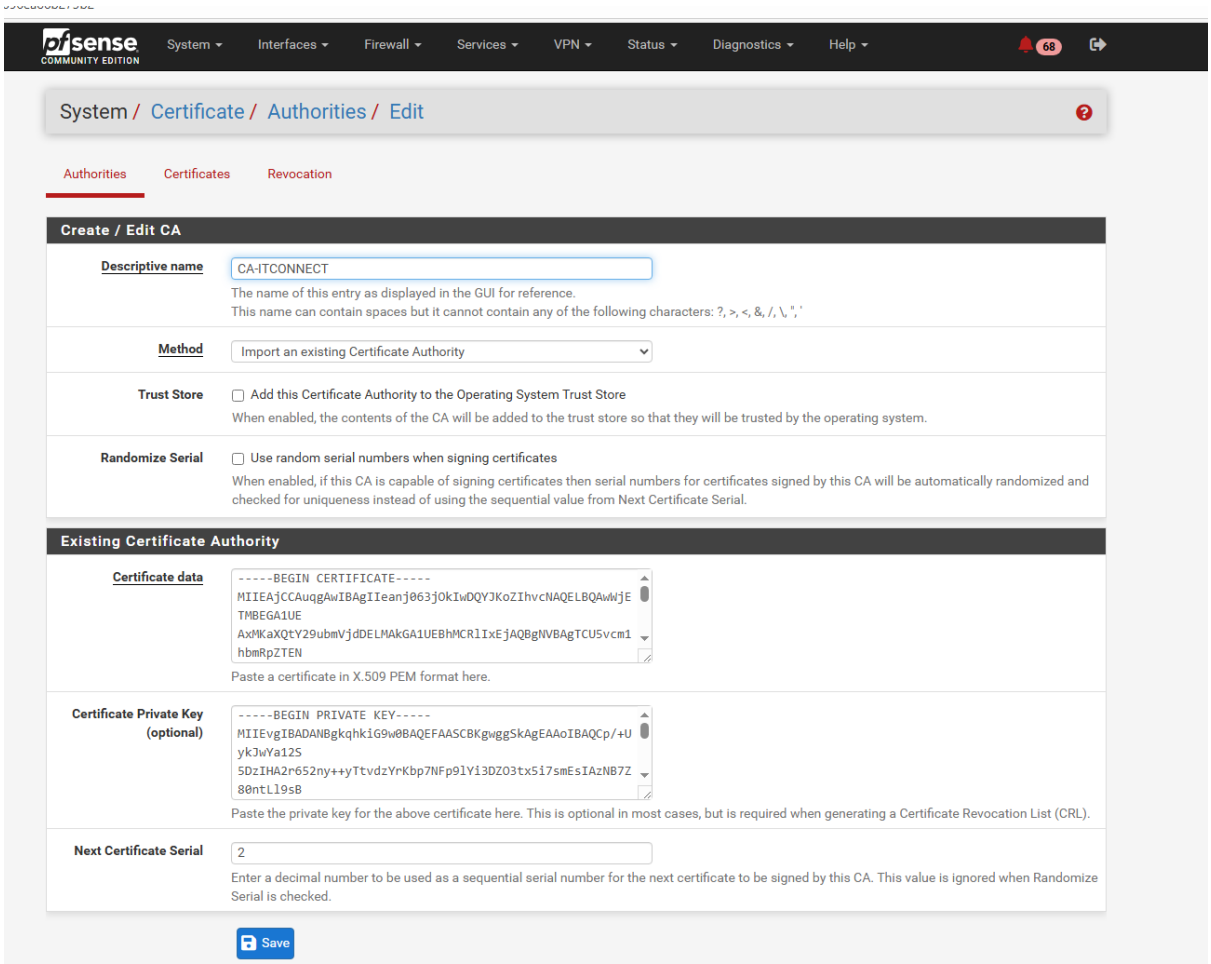
Dans cette configuration, la catégorie « réseaux_sociaux » est définie avec une action de type *deny*, ce qui signifie que tous les sites appartenant à cette catégorie sont bloqués. De la même manière, la catégorie « block_winamax » est également configurée en *deny*, afin d'empêcher l'accès aux sites de paris en ligne depuis le réseau interne. Ces règles sont prioritaires par rapport à l'accès par défaut.

L'accès par défaut, appelé *Default access [all]*, est quant à lui configuré en *allow*. Cela signifie que tous les sites qui ne correspondent à aucune règle de blocage spécifique restent accessibles aux utilisateurs. Cette logique permet de bloquer uniquement les sites ciblés, sans restreindre inutilement l'accès à l'ensemble d'Internet.

Le fonctionnement repose sur un ordre de traitement des règles. Lorsqu'un utilisateur tente d'accéder à un site web, SquidGuard analyse la requête en comparant l'URL demandée avec les catégories définies. Si le site correspond à une catégorie marquée comme *deny*, l'accès est immédiatement refusé. Si aucune règle de blocage ne correspond, l'accès est autorisé grâce à la règle par défaut.

Accès Distant Sécurisé (VPN)

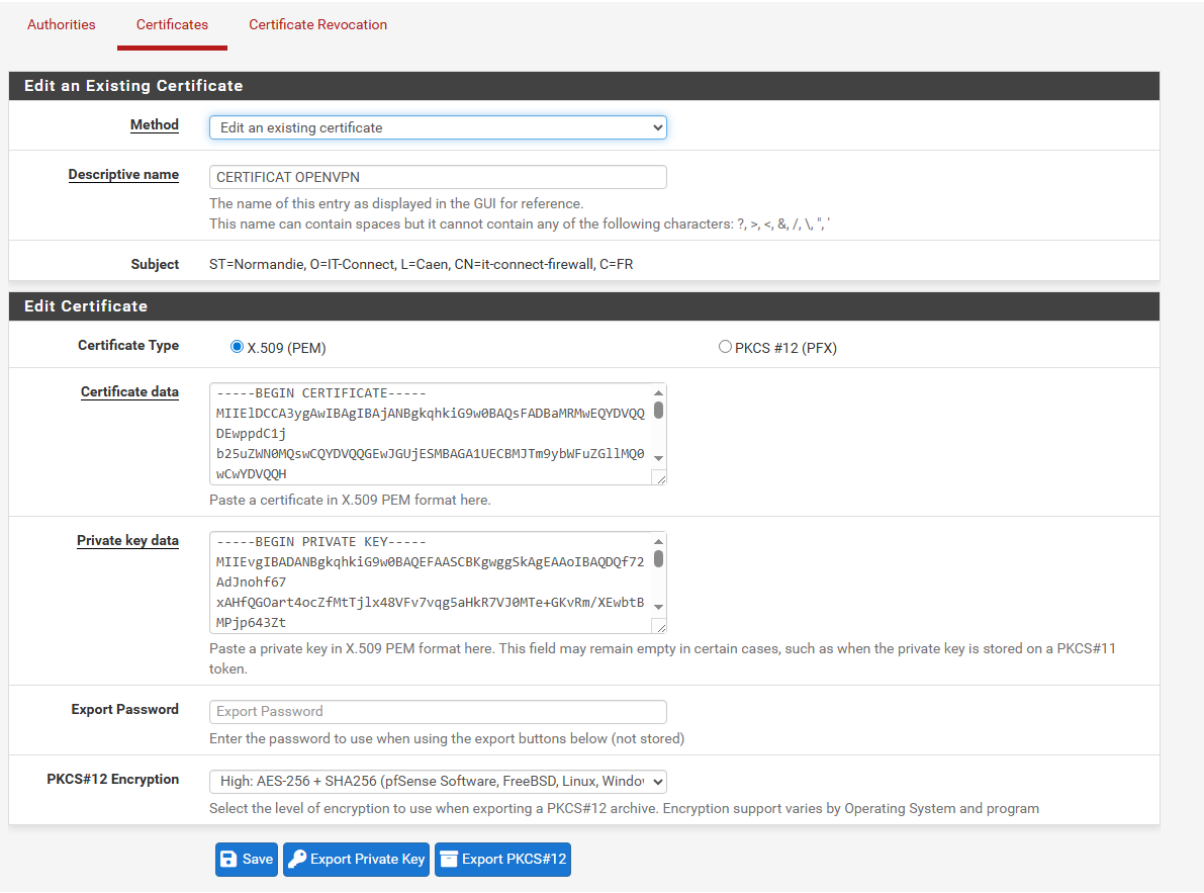
L'authentification des utilisateurs permet de contrôler l'accès au VPN.
Seuls les utilisateurs autorisés peuvent établir une connexion.
Cette étape garantit que l'accès distant est limité aux personnes légitimes.



Mise en place de l’autorité de certification (CA)

Dans le cadre de la mise en place du VPN, une autorité de certification est nécessaire afin de gérer les certificats utilisés pour sécuriser les connexions.
Une autorité de certification permet de garantir l’identité des équipements et des utilisateurs en signant les certificats utilisés par le serveur VPN et les clients.

Dans cette configuration, une autorité de certification existante a été importée dans pfSense. Cette méthode permet de réutiliser une infrastructure de certificats déjà en place, ce qui assure une meilleure cohérence avec le reste du système et facilite la gestion des certificats.



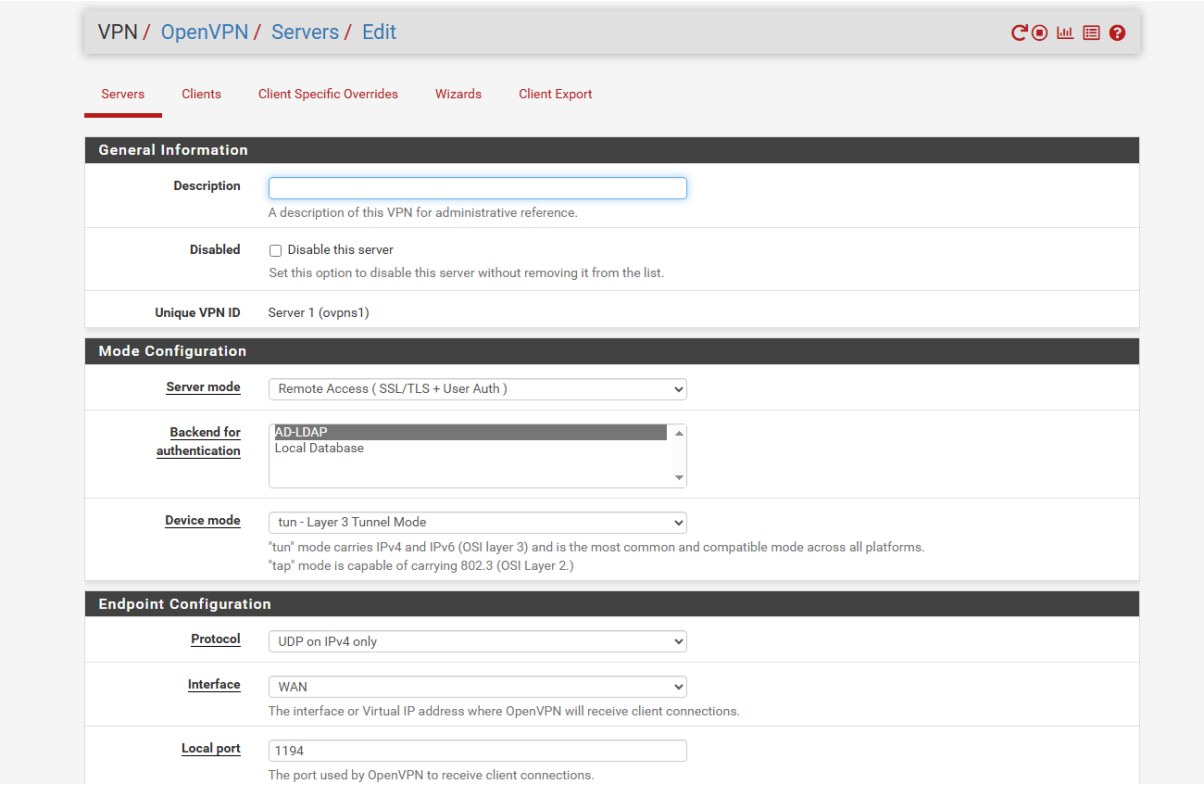
Création du certificat OpenVPN

Après l'importation de l'autorité de certification, un certificat est nécessaire pour le fonctionnement du serveur OpenVPN.
Ce certificat permet d'identifier le pare-feu pfSense lors de l'établissement de la connexion VPN et de sécuriser les échanges.

Le certificat utilisé est nommé **CERTIFICAT OPENVPN**, ce qui permet de l'identifier facilement dans la liste des certificats.
Il est basé sur le format **X.509 (PEM)**, qui est le format standard utilisé par OpenVPN.

Les informations du certificat (données du certificat et clé privée associée) sont renseignées afin de permettre le chiffrement et l'authentification des connexions VPN.
La présence de la clé privée est indispensable pour que le serveur OpenVPN puisse fonctionner correctement.

Ce certificat sera ensuite sélectionné lors de la configuration du serveur OpenVPN afin d'assurer une communication sécurisée entre le pare-feu et les clients VPN.



Configuration du serveur OpenVPN (accès distant)

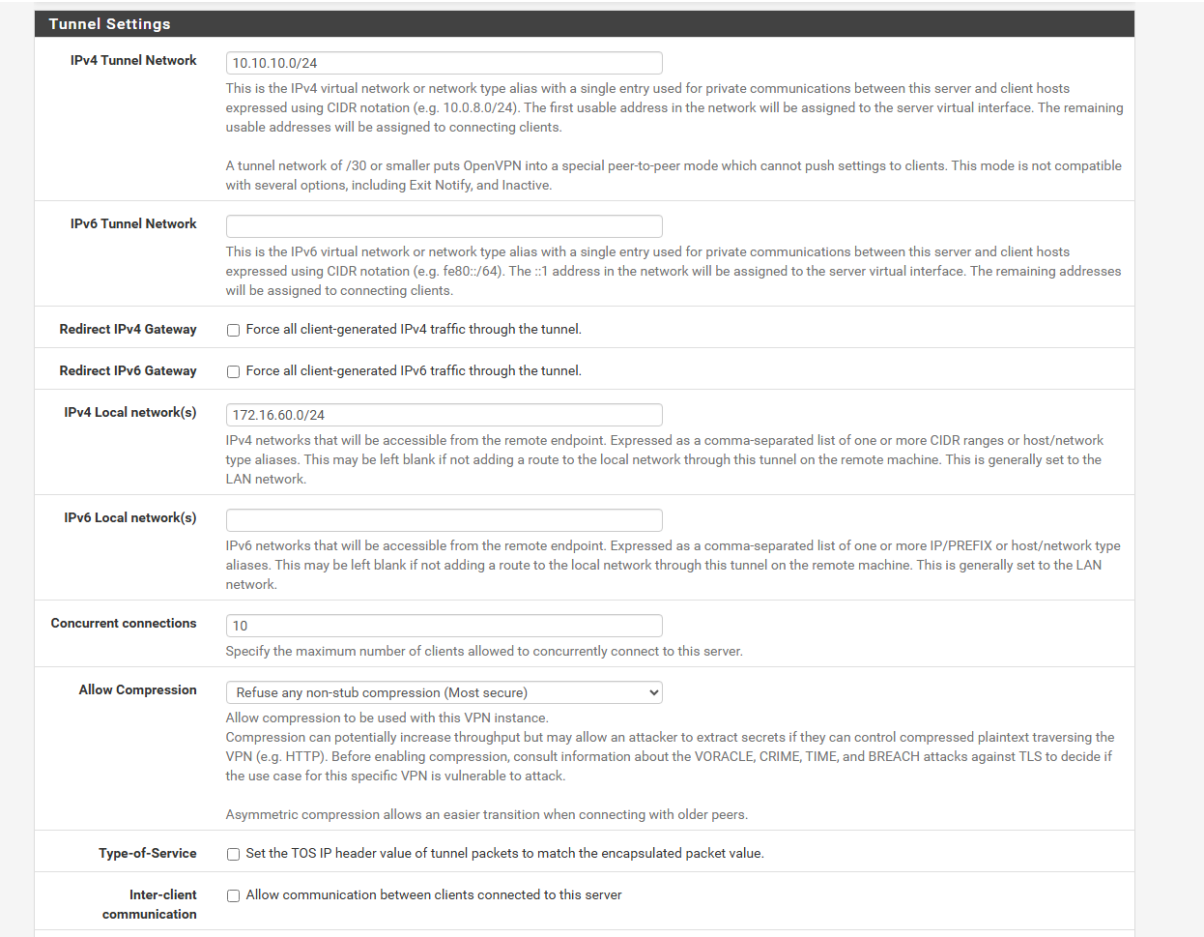
Un serveur OpenVPN est mis en place afin de permettre un accès distant sécurisé au réseau de l'entreprise.
Ce serveur est configuré en mode **Remote Access**, ce qui permet aux utilisateurs autorisés de se connecter depuis l'extérieur (Internet) vers le réseau interne.

Le mode **Remote Access (SSL/TLS + User Auth)** est utilisé. Il combine l'authentification par certificat et par identifiant utilisateur, ce qui renforce la sécurité des connexions VPN.
L'authentification des utilisateurs s'appuie sur l'annuaire **Active Directory (AD-LDAP)**, permettant une gestion centralisée des comptes.

Le mode de périphérique sélectionné est **tun (Layer 3)**. Ce mode crée un tunnel IP sécurisé entre le client et le pare-feu, et il est le plus couramment utilisé avec OpenVPN.

Le protocole utilisé est **UDP sur IPv4**, choisi pour ses bonnes performances et sa faible latence.
Le serveur OpenVPN écoute sur l'interface **WAN** du pare-feu, ce qui permet aux clients externes de se connecter depuis Internet.
Le port **1194**, port standard d'OpenVPN, est utilisé pour recevoir les connexions VPN.

Cette configuration permet aux utilisateurs distants d'accéder au réseau interne de manière sécurisée, tout en respectant les règles de sécurité définies sur le pare-feu



Tunnel Settings

IPv4 Tunnel Network	10.10.10.0/24 This is the IPv4 virtual network or network type alias with a single entry used for private communications between this server and client hosts expressed using CIDR notation (e.g. 10.0.8.0/24). The first usable address in the network will be assigned to the server virtual interface. The remaining usable addresses will be assigned to connecting clients. A tunnel network of /30 or smaller puts OpenVPN into a special peer-to-peer mode which cannot push settings to clients. This mode is not compatible with several options, including Exit Notify, and Inactive.
IPv6 Tunnel Network	This is the IPv6 virtual network or network type alias with a single entry used for private communications between this server and client hosts expressed using CIDR notation (e.g. fe80::/64). The ::1 address in the network will be assigned to the server virtual interface. The remaining addresses will be assigned to connecting clients.
Redirect IPv4 Gateway	☐ Force all client-generated IPv4 traffic through the tunnel.
Redirect IPv6 Gateway	☐ Force all client-generated IPv6 traffic through the tunnel.
IPv4 Local network(s)	172.16.60.0/24 IPv4 networks that will be accessible from the remote endpoint. Expressed as a comma-separated list of one or more CIDR ranges or host/network type aliases. This may be left blank if not adding a route to the local network through this tunnel on the remote machine. This is generally set to the LAN network.
IPv6 Local network(s)	IPv6 networks that will be accessible from the remote endpoint. Expressed as a comma-separated list of one or more IP/PREFIX or host/network type aliases. This may be left blank if not adding a route to the local network through this tunnel on the remote machine. This is generally set to the LAN network.
Concurrent connections	10 Specify the maximum number of clients allowed to concurrently connect to this server.
Allow Compression	Refuse any non-stub compression (Most secure) Allow compression to be used with this VPN instance. Compression can potentially increase throughput but may allow an attacker to extract secrets if they can control compressed plaintext traversing the VPN (e.g. HTTP). Before enabling compression, consult information about the VORACLE, CRIME, TIME, and BREACH attacks against TLS to decide if the use case for this specific VPN is vulnerable to attack. Asymmetric compression allows an easier transition when connecting with older peers.
Type-of-Service	☐ Set the TOS IP header value of tunnel packets to match the encapsulated packet value.
Inter-client communication	☐ Allow communication between clients connected to this server

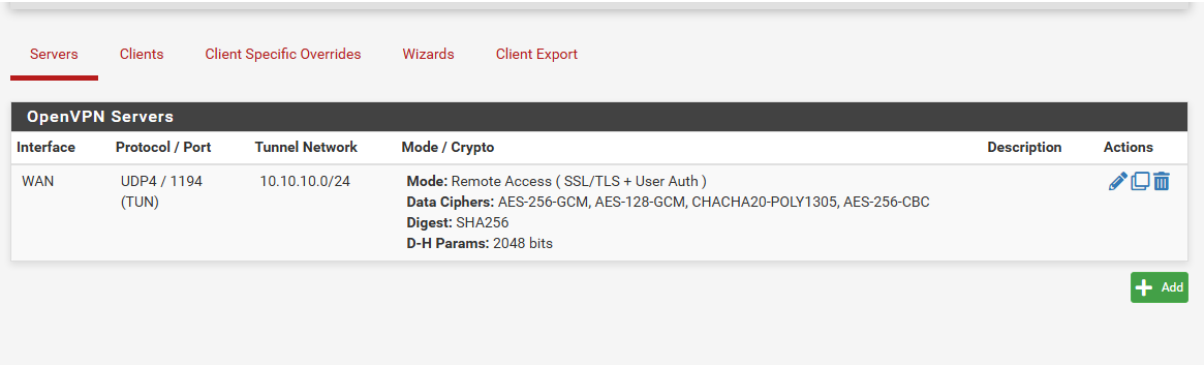
Le tunnel OpenVPN est configuré avec un réseau virtuel IPv4 dédié **10.10.10.0/24**.
Ce réseau est utilisé exclusivement pour les communications sécurisées entre le serveur OpenVPN et les clients distants. Chaque client VPN reçoit automatiquement une adresse IP dans cette plage lors de la connexion.

Le réseau local accessible via le VPN est défini sur **172.16.60.0/24**, qui correspond au réseau LAN interne de l'entreprise.
Cela permet aux utilisateurs connectés en VPN d'accéder aux ressources internes (serveurs, services, postes) comme s'ils étaient physiquement présents sur le réseau local.

Les options de redirection complète du trafic Internet (IPv4 et IPv6) ne sont pas activées.
Ainsi, seul le trafic destiné au réseau interne passe par le tunnel VPN, ce qui évite de surcharger le pare-feu et améliore les performances.

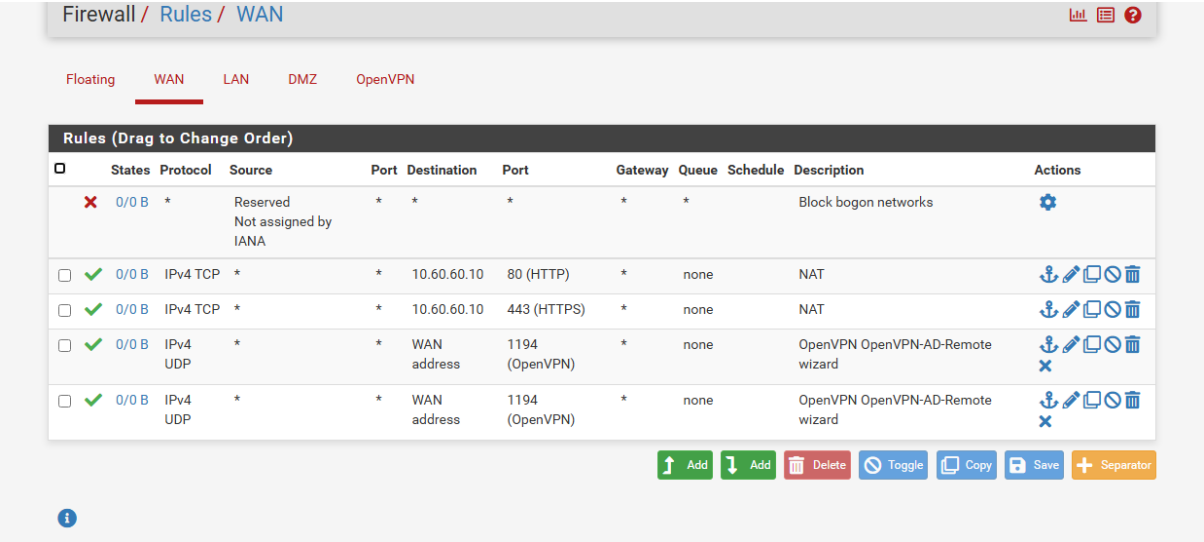
Le nombre de connexions simultanées est limité à **10 clients**, afin de contrôler l'utilisation du service VPN et garantir la stabilité du réseau.

La compression est désactivée (mode le plus sécurisé) afin d'éviter d'éventuelles vulnérabilités liées aux attaques sur les flux compressés.
La communication directe entre les clients VPN n'est pas autorisée, ce qui renforce l'isolation et la sécurité entre les utilisateurs distants.



Un serveur OpenVPN a été configuré sur l'interface **WAN** du pare-feu pfSense afin de permettre l'accès distant sécurisé au réseau interne de l'entreprise.
Le service utilise le protocole **UDP** sur le port **1194**, qui est le port standard recommandé pour OpenVPN, offrant de bonnes performances et une compatibilité élevée.

Le tunnel VPN repose sur le réseau virtuel **10.10.10.0/24**, attribué dynamiquement aux clients lors de leur connexion.
Le mode choisi est **Remote Access (SSL/TLS + User Authentication)**, ce qui signifie que l'authentification des utilisateurs repose à la fois sur des certificats numériques et sur des identifiants utilisateurs, renforçant ainsi la sécurité.



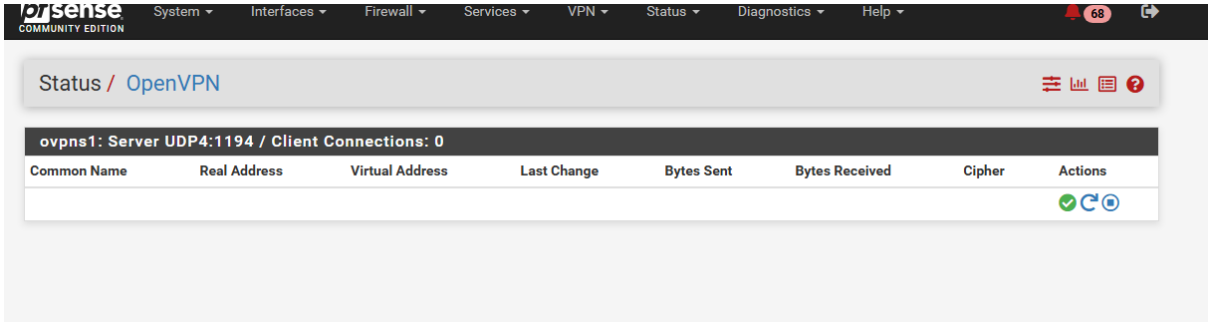
Des règles spécifiques ont été configurées sur l'interface **WAN** afin de permettre le fonctionnement du VPN **OpenVPN**.
Ces règles autorisent le trafic entrant en **UDP sur le port 1194**, qui correspond au port utilisé par le serveur OpenVPN.

Grâce à ces règles, les clients VPN distants peuvent établir une connexion sécurisée avec le pare-feu pfSense depuis Internet. Le protocole UDP a été choisi car il est plus performant et mieux adapté aux communications VPN.

Les règles ont été générées automatiquement via l'assistant de configuration OpenVPN, ce qui garantit leur compatibilité avec les paramètres du serveur VPN (port, protocole et interface).

Aucun autre trafic entrant n'est autorisé sur ce port, ce qui limite les risques de connexions non désirées.

Ces règles assurent donc un accès distant sécurisé au réseau interne tout en maintenant un niveau de sécurité élevé sur l'interface WAN.



D'après cette capture, le serveur OpenVPN est bien **actif et fonctionnel** sur le pare-feu pfSense.
Le service écoute correctement sur le **port UDP 1194** et aucune erreur n'est signalée.
Même si aucun client n'est actuellement connecté, le statut confirme que le **VPN est opérationnel et prêt à accepter des connexions distantes sécurisées**.

Phase 4 : Implémentation de la solution CrowdSec sur pfSense

Dans cette phase, l'objectif est de **renforcer la sécurité du pare-feu pfSense** en ajoutant un mécanisme de **détection automatique des comportements malveillants** et de **blocage dynamique des adresses IP attaquantes**.

1. Objectif de la phase

L'objectif de **CrowdSec** est de protéger l'infrastructure contre :

- les scans de ports,
- les tentatives de connexion répétées,
- les comportements anormaux venant d'Internet.

Contrairement à un pare-feu classique basé uniquement sur des règles statiques, **CrowdSec analyse le comportement des sources et agit automatiquement**.

---

2. Principe de fonctionnement de CrowdSec

CrowdSec fonctionne comme un système de **détection comportementale**.
Il analyse en temps réel les journaux générés par pfSense (pare-feu, services réseau, accès) afin d'identifier des schémas correspondant à des attaques connues.

Lorsqu'un comportement suspect est détecté (par exemple un scan de ports ou des tentatives répétées sur un service), CrowdSec :

- identifie l'adresse IP source,
- applique une décision de sécurité (bannissement),
- bloque automatiquement cette adresse IP via pfSense.

Ce mécanisme permet une réaction rapide et efficace face aux attaques, sans intervention manuelle de l'administrateur.

---

3. Installation et intégration de CrowdSec sur pfSense

Le service CrowdSec a été installé sur le pare-feu pfSense à l'aide du gestionnaire de paquets. Une fois installé, CrowdSec est configuré pour analyser les journaux système et réseau du pare-feu.

L'intégration avec pfSense permet :

- l'analyse des flux entrants depuis Internet,
- l'application automatique de règles de blocage,
- la mise à jour dynamique des décisions de sécurité.

Les adresses IP détectées comme malveillantes sont alors bloquées directement au niveau du pare-feu, ce qui empêche toute nouvelle tentative de connexion.

---

4. Test et validation du dispositif (Proof of Concept)

Afin de valider le bon fonctionnement de la solution, une phase de test a été réalisée à l'aide d'une machine **Kali Linux** positionnée sur le réseau WAN.
Depuis cette machine, des actions simulant une attaque ont été effectuées, notamment des scans de ports.

Ces comportements ont été correctement détectés par CrowdSec.
L'adresse IP source a été automatiquement bannie, ce qui a bloqué immédiatement toute tentative de connexion supplémentaire vers le pare-feu.

Ce test confirme :

- la bonne détection des comportements malveillants,
- l'efficacité du blocage automatique,
- l'intégration correcte de CrowdSec avec pfSense.

---

5. Apport de CrowdSec à la sécurité globale

L’ajout de CrowdSec renforce considérablement la sécurité de l’architecture réseau.
Il permet de compléter les règles de pare-feu statiques par une **protection dynamique et intelligente**, capable de s’adapter aux attaques en temps réel.

Cette solution améliore :

- la réactivité face aux menaces,
- la réduction de la surface d’attaque,
- la robustesse globale du pare-feu pfSense.

Conclusion générale du projet

Ce projet avait pour objectif de concevoir et de mettre en place une architecture réseau sécurisée répondant aux besoins d’une entreprise, tout en respectant les bonnes pratiques en matière de cybersécurité. À travers les différentes phases du projet, une solution cohérente et fonctionnelle a été déployée autour du pare-feu pfSense.

La mise en place du filtrage web à l’aide de Squid et SquidGuard a permis de contrôler l’accès à Internet et de bloquer certains sites non autorisés, tout en conservant une navigation normale pour les utilisateurs. Cette étape a montré l’importance du contrôle des usages afin de limiter les risques et les abus sur le réseau interne.

L’accès distant sécurisé par VPN OpenVPN a ensuite été configuré afin de permettre aux utilisateurs autorisés de se connecter au réseau depuis l’extérieur. Cette solution garantit la confidentialité des échanges grâce au chiffrement et à l’authentification, tout en offrant une réelle flexibilité pour l’administration à distance et le télétravail.

Enfin, l’ajout de la solution CrowdSec a permis de renforcer la sécurité globale de l’infrastructure. Grâce à l’analyse des journaux et au blocage automatique des adresses IP malveillantes, le pare-feu est désormais capable de réagir de manière dynamique face aux tentatives d’attaque.

Ce projet m’a permis de consolider mes compétences en administration réseau, en sécurité informatique et en gestion de pare-feu. Il m’a également aidé à mieux comprendre les enjeux liés à la protection d’un système d’information dans un contexte professionnel. L’architecture mise en place est fonctionnelle, évolutive et répond aux exigences de sécurité attendues dans un environnement d’entreprise.

PPE PFSENSE